Threat Intelligence

Threat evolution in Q2 2021

July 2021

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Ransomware 5

Threats to the government sector 6

FORECASTS FOR Q3 2021 **9**

DATA LEAKS IN Q2 2021 **10**

ADVANCED THREATS IN THE FINANCIAL SECTOR **12**

FINANCIAL THREATS **15**

Malware for Android 16

Threats and malware for PC 20

RANSOMWARE **27**

STATE-SPONSORED APTS **41**

Introduction

Every quarter Group-IB releases a report on the development of high-tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums, and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q2 saw the following APT campaigns against financial organizations:

- In late April 2021, Group-IB Threat Intelligence & Attribution specialists observed a new attack by RedCurl, a group that targets financial, travel, insurance, and construction companies as well as major retailers. In the new attack, the threat actors sent out emails in Russian purporting to be from a human resources department and Gosuslugi (a Russian government services portal). The group's goal is to infect computers in the target department in a given organization's infrastructure as well as to steal documents in which the hackers are interested. It was found that the hackers started using new tools in their recent attacks.
- It came to light that Lazarus (North Korea) is behind the CryptoCore malicious campaign, which was discovered last year and has been ongoing for three years. The campaign targets crypto-exchange companies; the group managed to make more than $200 million in two years.
- Andariel (North Korea) used new ransomware and demanded a ransom for decryption. All the targets are in South Korea.

Financial threats

- A new Android banking Trojan called TeaBot (Anatsa) was detected in May. Its functionality includes intercepting SMS messages, compromising credentials, and stealing money from bank accounts. The attacked regions include European countries (Spain, Germany, Italy, Belgium, and the Netherlands).
- TeaBot seems to have taken the place of the Android Trojan EventBot, which was active in Europe earlier but whose activity significantly decreased in Q2.
- Flubot was also active in Europe. Bulk SMS messages with the malware were detected in Germany, Spain, the Netherlands, Austria, Switzerland, and Belgium. The malicious messages are usually disguised as voice mail links.
- The Cerberus mobile banking Trojan attacked targets in Turkey.
- The Android Trojan FlexNet was active in the Commonwealth of Independent States (CIS), but its activity was low.
- As forecast, the Grandoreiro banking Trojan expanded beyond attacks against users in Latin America: victims in Belgium and the United States were detected.
- The Trojans Javali/Ousaban and Guildma/Astaroth were also active in Latin America. No activity from the Mexican banking Trojan BBtok was detected.
- IcedID was used to distribute ransomware such as REvil and Conti. The distribution schemes were the following:
    - Spearphishing Attachment (Possible SilentBuilder) -> GZIPLOADER -> IcedID -> Cobalt Strike-> BloodHound -> AdFind -> Rclone -> Revil
    - Abusing Contact Forms Campaign-> Redirect to Google Sites -> ZIP archive with JS -> GZIPLOADER-> IcedID-> Coblat Strike -> Conti
- As a banking Trojan, Qbot attacked the US and Canada. As a loader, it was used to distribute the DoppelPaymer ransomware.
- Mailouts with Gozi took place in Germany and Italy; Gozi was also involved in distributing REvil.
- Trickbot mailouts in English were detected. It can be concluded that the threat actors continue their activities despite the arrest of one of the group's members (Latvian citizen Alla Witte).
- SilentBuilder (aka EtterSilent), which is sold on underground forums, is currently used in many malicious mailouts. This is a builder for creating malicious MS Office documents.

- Group-IB specialists continue observing a lot of activity coming from JS bank card sniffers. The number of bank cards stolen using the Poter sniffer decreased insignificantly compared to the previous quarter. The operators of the Inter sniffer resumed their activity. A JS sniffer family called Worldcommerce was detected; it was used to compromise over 3,000 bank cards in a very short time, after which this activity was no longer observed. Group-IB specialists continue noting an increase in the number of infected websites as well as the number of threat groups that steal bank cards from users of online shops.
- Group-IB specialists detected and analyzed the activities of two threat groups that were active in Q2 2021 carrying out attacks against online shops to steal bank cards: the groups were named GrelosGTM and TrackStat.
- Gootkit attacks were detected in Germany and Canada. The Trojan has lately been used to distribute the REvil ransomware.
- SystemBC is still sold on forums and used for delivering CobaltStrike beacons. It was also found that SystemBC may have been used in the DarkSide attack against Colonial Pipeline.
- No new malware for POS terminals was detected.
- The zLoader/SilentNight banking Trojan was active in the US and Canada. The current distribution scheme is as follows: Malsmoke -> Fake Java Installer -> Zloader. Zloader was also involved in DarkSide ransomware attacks.
- Group-IB systems detected several samples of the BackSwap banking Trojan targeting Spain. In general, however, we assess the activity of this malware as low. Targets in the configuration file are: caixabank, bankia, bancsabadell.
- In April–May, researchers observed Danabot being distributed using the Cryptbot dropper.
- Among new databases in card shops, we highlight the following:
    - "epicmarket" – Canadian cards
    - "dumpstore" – Ecuadorian, Latvian and Mexican cards
    - "entershop" – Turkish and German cards
- Group-IB specialists discovered and analyzed threat actors that used U-Admin forks to attack European banks. These are groups such as Fraud Family (aka MultiPanel), Elprofesor, Runlir, Fexts, Derpzender, and Arra. These threat actors are located in the Netherlands. You can find more information about them in Threat Intelligence & Attribution.

Ransomware

Ransomware has become the biggest threat out there: we receive information about major incidents on a daily basis. Currently, we see that threat groups specifically target major companies with large revenues, which allows threat actors to demand significant ransoms for decrypting data.

This report covers only some of the incidents that have occurred. We detected a total of 22 groups being active in Q2 2021. The following new groups emerged: Hive, Grief, Prometheus, LV BLOG, Xing Locker, Lorenz, Arvin Leaks, vfo, Vice Society, and Qlocker.

Among major incidents, we highlight the following:

- On April 20, hackers from the REvil group gained access to the servers of Quanta Computer and stole Apple schematics. The threat actors demanded a $50-million ransom from Apple itself. They threatened to publish a new document every day leading up to May 1, unless Apple paid the ransom. The hackers deleted all the data from their website on the following day.
- On May 7, the DarkSide group attacked Colonial Pipeline, the largest pipeline operator in the US. The attackers took about 100 gigabytes of data out of the company's network and the company had to temporarily halt its operations. Because of that, the Federal Motor Carrier Safety

Administration at the United States Department of Transportation declared a state of emergency that covered 17 states and Washington D.C. After some time, the threat actors said that their goal was to make money and not create problems for the society. In the end, DarkSide said it was shutting down. The incident also had big consequences in the ransomware world leading to the closure of many affiliate programs. Colonial Pipeline resumed its operations on May 11.

- REvil attacked JBS Foods, one of the biggest meat producers in the world; as a result, the company had to suspend the operation of several of its facilities in the US, Australia, and Canada. JBS later admitted to paying the ransomware operators a part of the ransom. By doing so the company tried to regain access to the systems affected by the attack. The threat actors received $11 million in Bitcoin (they initially demanded $22.5 million).
- Sol Oriens, a US nuclear weapons contractor, also fell victim to REvil. The threat actors stole internal information as well as employee data including Social Security numbers and already put the data up for auction. The group published screenshots of various documents as evidence. To push Sol Oriens and make the organization pay the ransom, the threat actors threatened to share the compromised data with military agencies.
- On May 14, CNA Financial, a major US insurance company, suffered an attack. Hackers demanded $60 million for recovering affected data and not sharing the information they stole. After two weeks of negotiations, the insurer paid $40 million. CNA Financial was attacked by Phoenix Locker, which belongs to the Evil Corp group.
- On April 26, the Babuk threat group attacked the computer network of the D.C. police department. The group stole over 250 GB worth of data. Published screenshots suggested that the hackers had obtained access to investigation reports, officer disciplinary files, documents on criminal gangs and informants, and staff-related and administrative files. The threat actors gave the police several days to pay the ransom; otherwise, they threatened to contact local gangs and expose police informants. In the end, the Babuk Locker ransomware operators published personnel files of the D.C. police department's officers and informants on their website.
- The Prometheus ransomware emerged as early as March 2021. In April 2021, a related blog was launched; the attackers have had more than 45 victims.
- The activity of Conti is assessed as extremely high, with over 160 victim companies.
- In Q2, REvil attacked more than 100 companies.
- As at the end of Q2, the following threat groups' affiliate programs have been shut down: DarkSide and Avaddon. Other threat groups switched to working privately and stopped publicly recruiting people into their teams.
- The Babuk ransomware affiliate program now has a new owner. A new website with leaks was launched. In Q2, the Babuk ransomware had over 20 victims.
- A joint operation involving Interpol and Ukrainian, South Korean and US police resulted in six suspects related to the Cl0p ransomware being arrested.

Threats to the government sector

Q2 2021 saw the discovery of the following APT campaigns against government organizations:

- Kimsuky (North Korea) continued their attacks against government entities in South Korea, in particular, the Ministry of Foreign affairs, the International Atomic Energy Agency, the South Korean Atomic Energy Research Institute, the Seoul National University, etc. The attacks involved spear phishing, which resulted in the AppleSeed malware being downloaded (Windows and Android versions).
- It came to light that Cycldek hackers (China) may have conducted a new malicious campaign against government and military organizations located in Vietnam. The attacks involved FoundCore RAT, DropPhone, and CoreLoader.

- Facebook stopped APT-C-23 (Gaza) activities regarding using the social media as a way to distribute malware and engage in espionage.
- Gaza Cybergang (Gaza) continued their attacks against government entities in the Middle East, now with a new Trojan, LastConn.
- Unknown hackers conducted an attack against targets in Azerbaijan using a steganographic method and the FairFax.exe Trojan.
- Spanish-speaking hackers from the Machete group continued their attacks presumably against military organizations in Latin America and added publicly available LokiRat to their toolset.
- Gamaredon hackers (Russia) continued their malicious actions against Ukraine and used well-known spear-phishing techniques in their attacks. This time, however, they used new malware, which we named Gamaredon.NETDownloader, Gamaredon.MACStealer, and Gamaredon.Stealer.
- APT5 (China) used vulnerabilities in Pulse Secure appliances again, but now added zero-day vulnerability CVE-2021-22893 and employed 12 unique malicious tools.
- The UNC1151 group (Russian speakers) has been linked to a campaign that targets politicians and journalists in Eastern Europe with the aim of changing these countries' public opinion about the North Atlantic Treaty Organization (NATO). The threat actors' activities involve account compromises, spoofing of legitimate sites, and mailouts with malicious attachments that lead to the installation of RADIOSTAR, VIDEOKILLER, and HALFSHELL.
- It was found that Naikon (China) conducted attacks against military organizations in South-East Asia. The threat actors used two custom backdoors, RainyDay and Nabulae (both have full-fledged RAT functionality).
- Unknown threat actors carried out a campaign (dubbed Operation TunnelSnake) against targets in Africa and South Asia. The attacks involved a previously unknown rootkit for Windows called Moriya. It is known that the campaign was conducted from 2018 through May 2020.
- Transparent Tribe (Pakistan) continued creating websites imitating those of legitimate military and defense organizations in their attacks against India, Iran, and Afghanistan.
- New information came to light about the breach of a water facility in Oldsmar, Florida, United States. It was found that the organization's employees visited a contractor's website, which had earlier been compromised. It is yet unknown who is behind the attack.
- An unidentified hacker group from China attacked a small group of Uighurs living in Xinjiang and Pakistan. The threat actors disguised themselves as non-governmental organizations and the United Nations.
- New tools linked to the DRBControl campaign by APT27 (China) were discovered.
- A large-scale phishing campaign attributed to the DarkHalo group and samples of the malicious programs GoldMax, GoldFinder, and Sibot were detected. In addition, an attack primarily targeting IT companies and, to a lesser extent, government and non-governmental organizations, think tanks, and financial services was discovered.
- APT34 (Iran) carried out attacks against organizations in Lebanon using the SideTwist backdoor.
- A sample of APT32's (Vietnam) Linux backdoor RotaJakiro, which had not been detected by antivirus solutions for several years, was discovered.
- APT41 (China) conducted attacks against organizations in India and Taiwan. The campaign was named ColunmTK. Group-IB specialists discovered attacks against Air India, Changhua Christian Hospital, TVBS Media, National Development Fund of Taiwan, and Delta Electronics**.**
- Malware called SkinnyBoy, which is used in attacks against military and government institutions presumably by APT28 (Russia), was discovered.
- A new threat group called Agrius (Iran) has been attacking the Middle East, in particular, Israel and the United Arab Emirates (UAE). The hackers use the Apostle malware, which seems to be ransomware but destroys data in the end. In addition, the hackers deployed the DEADWOOD wiper, which has been linked to another Iranian group, APT33.
- It came to light that in 2020 hackers from China attacked Russia's federal agencies using the Trojans Webdav-O and Mail-O.

- Pakistani hackers (possibly Transparent Tribe) used a new remote access Trojan called ReverseRat and targeted government and energy organizations in South and Central Asia.
- A new group called SharpPanda (China) remained unnoticed for three years and attacked a South-East Asian government.
- Mustang Panda (China) is believed to have carried out a watering hole attack against Myanmar President's website; the group presumably installed Cobalt Strike.
- A previously unknown group called PuzzleMaker is behind targeted attacks worldwide, in which they used zero-day vulnerabilities in Microsoft Windows (CVE-2021-31955 and CVE-2021-31956) and Google Chrome.
- Another new hacker group, called Gelsemium, specializes in cyber espionage and has been active since at least 2014. The APT's main targets have lately been governmental institutions, electronics manufacturers, universities and religious organizations in East Asia and the Middle East.
- A new APT group called BackdoorDiplomacy due to the main vertical of its victims has been targeting ministries of foreign affairs and telecommunication companies in Africa and the Middle East since at least 2017.
- Security researchers reported that a new group tracked as Ferocious Kitten (Iran) used instant messaging apps and VPN software like Telegram and Psiphon to deliver MarkiRAT and spy on targets.
- Norwegian authorities said that APT31 (China) was behind the attack that breached the government's IT network in 2018. Investigators say no evidence that the threat actors exfiltrated government secrets or personal sensitive information related to Norwegian citizens has been found.
- Zyxel alerted its customers about a series of attacks by unknown hackers that targeted some of the company's enterprise-focused firewall and VPN server products.
- Security researchers identified ties between the RedFoxtrot threat group and China's People's Liberation Army (PLA) Unit 69010. RedFoxtrot attacks predominantly target the government, telecommunications and defense sectors across Central Asia, India, and Pakistan.
- Between April and June, Sidewinder (India) attacks against Pakistan, China, and Nepal were detected. Group-IB specialists also discovered a Telegram bot to which a stealer sends stolen data.
- Lazarus (North Korea) was involved in several major operations, including the ongoing Dream Job campaign. The hackers attacked military and pharmaceutical companies, used new methods to hide their presence, and employed Vyveva, a previously undocumented Trojan.

Forecasts for Q3 2021

- Many threat actors have shut down their public affiliate programs for ransomware on underground forums. We believe, however, that they will not halt their activities and will simply switch to working privately. Attacks and large ransom demands will continue.
- Banking Trojans will be focused on working with ransomware operators. Qbot, however, will continue attacking banks in North America, while Gozi will do so in Europe.
- Credit card sniffers will remain a relevant threat. Group-IB specialists continue detecting infections on many websites. We have also seen a rise in the number of groups that use this type of tool in their attacks.
- TeaBot, FluBot, and Cerberus will be the most dangerous Android Trojans in Europe.
- Grandoreiro, Javali, and Guildma (Astaroth) will be active in Latin America.
- RedCurl may attack companies in Russia and other CIS countries.
- We forecast that the coming months might see new supply-chain attacks similar to breaches at SolarWinds, SITA, and Kaseya (the latter is a new attack that happened in Q3), which will result in many attacks against companies working in IT and cybersecurity as well as cloud infrastructures.

Data leaks in Q2 2021

- Early June saw messages on hacker forums about a theft of about 780 GB of source code, proprietary frameworks, development tools (SDK) and engines from Electronic Arts. All the stolen data, including access to FIFA 21 servers, FIFA 22 API keys and some SDKs for Microsoft Xbox and Sony, has been put up for sale.
- MobiKwik (India): a threat actor claimed to have downloaded 8 TB of data from the company, including 3.5 million records with information about customers as well as 99 million customers' phone numbers, emails, hashed passwords, addresses, bank account information, and payment card details.
- Carding Mafia, a carding forum, was hacked, exposing the email addresses, IP addresses, usernames, and hashed passwords of 297,744 users.
- Allina Health (US): Netgain Technology, which is the IT services provider for Apple Valley Clinic, Minnesota, US, was hacked. Names, dates of birth, social security numbers, bank account and medical information were compromised, affecting 157,939 individuals.
- Facebook (US): names, mobile phone numbers, dates of birth, email addresses and other information about 533,313,128 users were leaked online. According to Alon Gal, this happened because of a now-patched vulnerability in Facebook's "Add Friend" feature.
- ParkMobile (US): the data of the application's 21 million customers was put up for sale on an underground forum. The stolen information includes email addresses, dates of birth, phone numbers, license plate numbers, and hashed passwords.
- Some 246 GB worth of data belonging to 59 million US residents were put up for sale on Raidforums. The information includes names, phone numbers, email addresses, residence addresses, dates of birth, income details, and political affiliation. The data is believed to have been put up for sale for the purposes of adjusting targeting activities.
- A hacker named Pompompurin leaked a database of 250,806,711 American citizens and residents. The data included names, phone numbers, addresses, dates of birth, and credit and income information.
- BtcTurk (Turkey): the data of 516,954 users of the service was leaked on a forum. The information included names, citizenship ID numbers, email addresses, dates of birth, and mobile phone numbers.
- DailyQuiz: the data of 12.8 million users was leaked online following an earlier breach of the site's database. The leak contains passwords, emails, and IP addresses.
- BPJS Kesehatan (Indonesia): the data of more than 200 million accounts from the healthcare website's database were stolen. The data includes names, dates of birth, phone numbers, email addresses, IDs, and, in some cases, income information.
- Omiai (Japan): 1,710,000 users' data such as driver's licenses, health insurance cards and passport details was stolen as a result of an attack.
- 20/20 Eye Care Network (USA): on January 11, 2021, the company was alerted to suspicious activity in its Amazon Web Services (AWS) environment. An investigation revealed that the data of 3,253,822 individuals may have been removed and then deleted. The data included names, addresses, Social Security numbers, member identification numbers, dates of birth and health insurance information.
- AMT Games (China): researchers discovered an unsecured server belonging to AMT Games, containing unencrypted Battle for the Galaxy user data. A total of 1.47 TB was exposed, including 5.9 million user records.
- New York Pizza (Netherlands): the data of 3.9 million customers of the pizza chain was compromised, including email addresses, delivery addresses, phone numbers, and passwords.
- Volkswagen (Germany) said that data about 3.3 million customers of the company was left exposed by one of its vendors. The exposed information relates to data from 2014 to 2019 and was freely accessible between August 2019 and May 2021. Most of the compromised data included names, postal and email addresses, and phone numbers. Customers from the United States and Canada also had information such as driver's license numbers, dates of birth, and Social Security numbers exposed.

Advanced threats in the financial sector

Threat name	Detection	Regions attacked
RedCurl	2018	Russia

In late April 2021, Group-IB Threat Intelligence & Attribution specialists observed a new attack by RedCurl, a group that targets financial, travel, insurance, and construction companies as well as major retailers. The hackers have up-to-date information on the current employees of targeted departments and send spear-phishing emails with decoy documents. In their attacks, the threat actors obtain all Office documents, text files, and images. The group was discovered in 2018. In the group's earlier attacks, tools such as FirstStageAgent, Channel1, and Channel2 were PowerShell scripts. In recent attacks, however, RedCurl employed new tools, which were discovered during our analysis.

To gain initial access, RedCurl uses spear phishing. To make the activities appear more legitimate, the emails are crafted for each targeted organization individually. During our analysis we observed two phishing campaigns against one organization. The first mailout was disguised as coming from a human resources department between April 27 and April 29, 2021. The second mailout purported to be from a government services portal and took place on May 25, 2021. The emails were sent out from accounts registered on Outlook.

The emails contain links to 7z archives. Within the archives is a malicious LNK file (RedCurl.InitialDropper), which downloads a PowerShell script (RedCurl.PS-Stager). The tasks of RedCurl.PS-Stager include downloading and ensuring persistence for the next stage (RedCurl.Downloader); the script also downloads a decoy document and shows it to the user. Links that are used for downloading the next stage and the decoy document are located in the body of RedCurl.PS-Stager. RedCurl.PS-Stager is not saved in the infected system and is launched in memory on the infected machine (fileless).

RedCurl.Downloader is an executable file that communicates with an attacker-controlled server through the HTTP protocol using POST requests. A list of addresses with which it communicates is located in the body of the executable file in an encrypted form. During its operation, RedCurl.Downloader sends initial information about the infected system to the attackers. At the end of its operation, it downloads the next stage, RedCurl.Dropper.

Like in previous versions, the main task of RedCurl.Dropper is to extract and ensure persistence for a module that is responsible for command execution on the infected system (RedCurl.FirstStageAgent). Persistence in the system is ensured by creating a recurring task in Windows Task Scheduler. Together with RedCurl.FirstStageAgent, the 7-zip utility version 19-00 is extracted. Previous RedCurl.FirstStageAgent versions received commands from a cloud drive through the WebDAV protocol. In the new versions of the FSA module, commands are received by sending POST requests. Another distinct characteristic is the fact that the FSA module no longer extracts the modules Channel1 and Channel2. However, the group continues using the modules themselves. At the moment, we believe that the modules are delivered to infected systems using a separate command, which has not been identified. The commands (RedCurl.Commands) are BAT scripts that in terms of their implementation are not different from previous attacks. The commands upload their outcomes to a legitimate cloud drive using the WebDAV protocol.

The threat actors registered third-level domains on free hosting services. The threat actors used the registered domains for both downloading next stages and ensuring communication with their servers.

Our analysis revealed that the threat group continues using the tools LaZagne and ADExplorer to collect additional information about infected machines.

APT name	Regions attacked	Operation start
Lazarus	USA, Japan, Turkey, China, Israel, Hong Kong, Vietnam, UK, Russia	2018

It was found that Lazarus is behind the CryptoCore malicious campaign discovered last year. CryptoCore is an attack campaign against crypto-exchange companies that has been ongoing for three years and was discovered by ClearSky researchers. This cybercrime campaign is focused mainly on the theft of cryptocurrency wallets; the attackers are believed to have already made off with hundreds of millions of dollars. This campaign was reported by various companies and organizations, including JPCERT/CC, NTT Security, and F-SECURE. The campaign is also known as CryptoMimic, Dangerous Password and Leery Turtle.

The CryptoCore group is known for having accumulated approximately $70 million from its heists on exchanges. Experts estimate that the group managed to rake in more than $200 million in two years.

The key goal of CryptoCore's heists is to gain access to cryptocurrency exchanges' wallets, be it general corporate wallets or wallets belonging to the exchange's employees. For this kind of operation, the group begins with an extensive reconnaissance phase against a company, its executives, officers and IT personnel.

Spear-phishing is typically carried out by impersonating a high-ranking employee either from the target organization or from another organization (e.g. advisory board) with connections to the targeted employee. After gaining an initial foothold, the group's primary objective is to obtain access to the victim's password manager account. This is where keys of crypto-wallets and other valuable assets – which will come in handy in lateral movement stages – are stored.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.

APT name	Regions attacked	Operation start
Andariel	South Korea	2020

A malware campaign targeting South Korean entities that came to light earlier this year has been attributed to a North Korean nation-state hacking group called Andariel.

The findings from experts build upon a previous report from Malwarebytes in April 2021, which documented a novel infection chain that distributed phishing emails weaponized with a macro embedded in a Word file that is executed upon opening in order to deploy malicious code concealed in the form of a bitmap (.BMP) image file to drop a remote access trojan (RAT) on targeted systems.

According to the latest analysis, the threat actors, besides installing a backdoor, are also said to have delivered file-encrypting ransomware to one of their victims, implying a financial motive to the attacks.

The ransomware is designed to encrypt all files on the target machine with the exception of system-critical .exe, .dll, .sys, .msiins, and.drv extensions in return for paying a bitcoin ransom to gain access to a decryption tool and unique key to unlock the scrambled files.

Andariel is a subgroup of Lazarus, a notorious North Korean threat group. Andariel presumably started their activities in 2014 and has been targeting South Korean government entities and companies using specifically tailored attack methods.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked
FluBot	January 2021	Germany Spain Netherlands Austria Switzerland Belgium

This banking Trojan was discovered in early 2021. Its main function is to show fake login screens on top of other applications. As such, FluBot collects victims' electronic banking credentials and payment card details.

The malware is distributed through mass SMS spamming. Once the victim's device is infected, threat actors can upload the contact list to their command-and-control (C&C) server and send spam SMS messages from there. Links in the messages usually lead to hacked websites, where FluBot operators place their malware in the form of APK files.

FluBot does not have full control over the device unless the user provides it with access to the Accessibility service. If the rights are obtained, the malware can execute commands and simulate touching the screen, while remaining invisible to the owner of the device. As a result, FluBot is capable of intercepting and blocking app notifications, setting itself as the default SMS app, using USSD, making phone calls, and stealing contact lists. In addition, access to Accessibility allows the Trojan to display phishing screens over other legitimate applications.

In Q2 2021, bulk SMS messaging involving this malware was detected in Germany, Spain, the Netherlands, Austria, Switzerland, and Belgium. The malicious messages are usually disguised as voice mail links.

Threat name	Detection	Regions attacked
TeaBot (Anatsa)	March 2021	Spain Germany Italy Belgium Netherlands Russia

A wave of attacks involving TeaBot (Anatsa), a new Android banking Trojan, was detected in May. Its functionality includes intercepting SMS messages, compromising credentials, obtaining a live stream of the target device's screen, intercepting keystrokes, accessing Google Authenticator 2FA codes, and, ultimately, stealing money from bank accounts. The attacked regions include European countries (Spain, Germany, Italy, Belgium, and the Netherlands). The collected data is sent to a remote server controlled by the attackers every ten seconds.

The malware imitates media and delivery services such as TeaTV, VLC Media Player, DHL, and UPS. It was also revealed that the malicious program was distributed disguised as the Russian government app Gosuslugi, which means that the malware also targets victims in Russia.

Below are examples of targeted apps from a Teabot configuration file extracted by Group-IB specialists:

es.lacaixa.mobile.android.newwapicon
es.cm.android
es.bancosantander.apps
com.bbva.bbvacontigo
net.inverline.bancosabadell.officelocator.android
com.kutxabank.android
es.ibercaja.ibercajaapp
es.liberbank.cajasturapp
es.openbank.mobile
app.wizink.es
com.grupocajamar.wefferent
piuk.blockchain.android
com.binance.dev
com.coinbase.android
vivid.money
de.commerzbanking.mobil
de.comdirect.android
com.mobileloft.alpha.droid
com.starfinanz.smob.android.sfinanzstatus
de.fiducia.smartphone.android.banking.vr
de.ingdiba.bankingapp
de.postbank.finanzassistent
de.santander.presentation
de.sdvrz.ihb.mobile.secureapp.sparda.produktion
de.traktorpool
eu.unicreditgroup.hvbapptan
com.db.pbc.miabanca
com.db.pwcc.dbmobile
com.ing.mobile
nl.regiobank.regiobankieren
bvm.bvmapp
com.triodos.bankingnl
com.abnamro.nl.mobile.payments
nl.rabomobiel
nl.asnbank.asnbankieren
de.dkb.portalapp
be.belfius.directmobile.android
be.argenta.bankieren
com.db.pbc.mybankbelgium
com.beobank_prod.bad
be.axa.mobilebanking
be.bmid.itsme
com.ing.banking
com.bnpp.easybanking.fintro
com.bnpp.easybanking
com.kbc.mobile.android.phone.kbcbrussels
com.kbc.mobile.android.phone.kbc
be.keytradebank.phone
com.bpb.mobilebanking.smartphone.prd
exodusmovement.exodus
com.unicredit
com.latuabancaperandroid

it.bnl.apps.banking
it.copergmps.rt.pf.android.sp.bmps
posteitaliane.posteapp.appbpol
it.carige
posteitaliane.posteapp.apppostepay
co.mona.android
posteitaliane.posteapp.appposteid
com.fineco.it
de.number26.android
it.phoenixspa.inbank
it.icbpi.mobile
it.widiba.bol
it.iwbank.banking
it.gruppobper.ams.android.bper
com.cajaingenieros.android.bancamovil
com.indra.itecban.triodosbank.mobile.banki
com.mediolanum
es.evobanco.bancamovil
com.indra.itecban.mobile.novoba
es.cecabank.ealia2103appstore
com.imaginbank.app
es.caixabank.caixabanksign
es.caixagalicia.activamovil
es.bancosantander.empresas

Threat name	Detection	Regions attacked
Cerberus	April 2020	Global

The Android banking Trojan Cerberus can send and intercept SMS messages, show web fakes to the user, record keystrokes (keylogger), launch applications installed on the device, bypass security restrictions and antiviruses, create fake PUSH notifications, and open URLs in the browser.

This malware is an updated version of the Cerberus Android bot created in June 2019. Later in 2019, the source code was published free of charge for premium users of one forum. Posts with the Trojan's source code continue to be occasionally published on underground forums, which means that many threat actors have been using it.

In Q2, Cerberus distribution was observed in Turkey.

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from the C&C server, the application can:

- Change the C&C server address

- Send an SMS message to a specified number
- Send bulk SMS messages with a specified text
- Forward SMS messages to a remote server
- Reply to SMS messages and delete them to conceal the fact from the user
- Run USSD requests
- Schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialog boxes added to its functionality. They are disguised as popular applications and designed to obtain the victims' bank card details. The following fake dialog boxes were detected:

AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked
GrelosGTM threat group	April 2020	Global

The group started its activity in January 2020. At the time, the group used a modified JS sniffer (which was based on publicly available source code) to attack online shops. The group later switched to using a commercial product, the Inter JS sniffer. During a campaign that started in February 2021, the group used a legitimate service, Google Tag Manager, to inject malicious code for stealing bank card details into the code of websites. Online shops operating in Belgium, Italy, Indonesia, the UK, and the US were attacked.

Threat name	Detection	Regions attacked
TrackStat threat group	April 2020	Global

The TrackStat group has been carrying out attacks against online shops using JS sniffers for stealing cards since at least December 2019. A distinct characteristic of the group is its use of special code that checks whether a user is on a payment page as well as the use of free hosting services to host malicious code. Over the time it has been active, the group has attacked 44 websites operating in the UK, the US, Australia, Italy, Brazil, India, Romania, Spain, Estonia, France, Hungary, Lithuania, the Netherlands, Pakistan, and Turkey.

Threat name	Detection	Regions attacked
zLoader/Silent Night	November 2019	USA Canada

This Trojan was put up for sale in late 2019. At the end of Q1 2020, it started being used in the wild. It is mostly distributed through mailouts with a macro-containing Excel file, which downloads zLoader.

Based on analyses of zLoader panels, Group-IB specialists established that victim devices were mostly located in the US and Canada.

The current zLoader distribution scheme is as follows: Malsmoke -> Fake Java Installer -> Zloader. In addition, researchers said in May that zLoader had been involved in DarkSide ransomware attacks.

Threat name	Detection	Regions attacked
Trickbot	2016	Global

Since 2020, in addition to being used as a banking Trojan, Trickbot has been used in ransomware attacks.

In 2020, Trickbot was fitted with new features:

- Bypassing UAC in Windows 10 (it was previously available only for Windows 7) to deliver malware to numerous machines in the target network.
- Use of Windows 10 ActiveX to execute malicious macros.
- Module for using hacked machines for RDP brute-force attacks.
- In May 2020, Palo Alto Networks discovered that Trickbot's propagation module called nworm had been updated. Infections caused through it leave no artifacts in the victim's domain controller, which disappear after a reboot or shutdown. It is run from RAM. In addition, unlike the previous module (mworm), the new module transfers Trickbot's executable file in encrypted form.
- In October, a new Trickbot feature was discovered, which enables threat actors to tamper with UEFI/BIOS. The new module checks the SPI controller to see if BIOS write protection is enabled. The module has not been witnessed modifying the firmware itself, though it already contains code to read, write, and erase firmware. The new module has not yet been detected in use in actual attacks.
- In February 2021, a new component was added. It performs local network reconnaissance. Named masrv, the component incorporates a copy of the Masscan open-source utility in order to scan local networks for other systems with open ports. The idea behind masrv is to drop the component on newly infected devices, send a series of Masscan commands, let the component scan the local network, and upload the scan results to a Trickbot C&C server.

Despite the arrest of a Trickbot member (Latvian citizen Alla Witte), the threat actors continue their activities. Mailouts in English were detected in June.

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Italy Germany

Gozi/ISFB is a banking Trojan that was created quite a long time ago. In 2020-2021, Group-IB specialists observed the use of Gozi 2.X and Gozi v3.
The malware's main features include:

- MITB (Man-In-The-Browser) attacks using web injects
- Theft of user accounts from infected devices
- Execution of CMD commands
- Download of files to an infected device and their execution
- Extension of functionality through the download of additional modules from the C&C server
- Video recording

Q2 2021 saw phishing mailouts distributing Gozi in Italian and German.
Below is a list of targets from the configuration file:
amazon.it
bancagenerali.it
bancobpm.it
banking.sparda
banking4you.it
bnl.it
bpergroup.net
cabel.it
cariparma.it
carispezia.it

cbibanking.it
chebanca.it
chebanca.net
comdirect.de
commerzbank.de
consorsbank.de
credem.it
credit-agricole.it
creval.it
csebo.it
deutsche-bank.de
dkb.de
ebay
fideuramonline.it
fidor.de
finecobank.com
friuladria.it
gruppocarige.it
hypovereinsbank.de
inbank.it
ing.de
intesasanpaolo.com
mps.it
netbank.de
nexi.it
norisbank.de
paypal
paypal.com
popso.it
postbank.de
poste.it
relaxbanking.it
seceti.it
securebank.santander
sella.it
signin.ebay
targobank.de
tecmarket.it
ubibanca.com
unicredit.it
unipolbanca.it

Gozi was also used by the TA551 group in attacks distributing Qbot and the REvil ransomware.

Threat name	Detection	Regions attacked
SystemBC	2018	Global

The past quarter saw activity of the SystemBC malware. A new panel was discovered. The main victims in it are related to India, Indonesia, and Pakistan. Detected victims include government entities, universities, and banks.

In addition, it was found that SystemBC was presumably used in the DarkSide attack against Colonial Pipeline.

The SystemBC malware uses SOCKS5 proxies. It uses a beacon on the infected machine and establishes new proxy connections between the C&C server and remote hosts. The proxy connections are RC4-encrypted. The malware receives commands through HTTP and creates new proxy connections as instructed. It is sold on exploit[.]in, an underground forum, under the name sock5 backconnect system. SystemBC is usually used for hiding malicious traffic associated with other malware. It was detected that the malware was downloaded and used for this purpose by Danabot, Smokeloader, and ISFB (Gozi) as well as employed in ransomware attacks (REvil, Ryuk).

Threat name	Detection	Regions attacked
Gootkit	2014	Germany Canada

We have not seen any activity from the Gootkit banking Trojan since October 2019. However, in December 2020 it reappeared on the radar. Security specialists discovered a malicious campaign targeting users in Germany. The campaign involved both the Gootkit Trojan and the REvil ransomware, which may suggest that the Gootkit operators decided to shift their focus to working with ransomware.

When the user clicked on a link in an email, they downloaded a ZIP file containing an obfuscated JS file (Gootloader loader) that installed either the Gootkit malware or the REvil ransomware. The same attack method had previously been used by REvil operators in September 2019, around the same time that Gootkit disappeared.

In Q2 2021, mailouts involving Gootkit were detected in Canada and Germany.

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	France Italy

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and many features of Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's distinct characteristics is its ability to deploy a proxy server on an infected machine and redirect all Internet traffic using that server.

In addition to banks, IcedID currently attacks e-commerce businesses. In either case, threat actors' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

In May 2020, Group-IB specialists analyzed a new version of IcedID (21st one), in which configuration files were hidden in PNG images. In earlier versions (e.g., 12), the PNG file only contained the main module.

In mid-2020, it was discovered that the Valak loader started to be used to distribute IcedID.

In 2021, IcedID was primarily used to distribute ransomware such as REvil and Conti. The distribution schemes were the following:

- Spearphishing Attachment (Possible SilentBuilder) -> GZIPLOADER -> IcedID -> Cobalt Strike-> BloodHound -> AdFind -> Rclone -> Revil
- Abusing Contact Forms Campaign-> Redirect to Google Sites -> ZIP archive with JS -> GZIPLOADER-> IcedID-> Coblat Strike -> Conti

Threat name	Detection	Regions attacked
Qbot	2009	USA, Canada

Qbot (QakBot) emerged in 2009 and has since been regularly improved. Qbot is a modular multithread Trojan that can steal banking data, digital certificates, authentication tokens, and cookies as well as function as a keylogger, backdoor, and SOCKS proxy; it also has antivirus evasion features. Qbot is designed to target businesses and steal money from their bank accounts. The Trojan is distributed as a worm by self-replicating through shared drives and removable media.

In 2020, the Qbot operators, as well as those of other banking Trojans, decided to shift their focus toward distributing ransomware. In particular, the Qbot operators worked with the Egregor ransomware. They later worked with the DoppelPaymer ransomware.

The configuration file of the latest detected samples of Qbot contains the following targets:

Chase
BB&T
Citizensbank
Capitalone
Firstcitizensonline
Suntrust
Wellsfargo
Frostbank
Scotiabank
Bank of America
Bank of Montreal
Royal Bank of Canada
Citibank
Bank of the West
EastWest Bank
Fifth Third Bank
HSBC
JP Morgan
Mandt Bank
The PNC Financial Services Group
TDBank
Usbank
Amegybank
National Bank of Arizona
Vectrabank
Zionsbank
Schwab
Desjardins
Scotiabank

In the latest Qbot updates, the network protocol and security mechanisms (security checks on the server side) have been improved. A security check has been integrated to send data only one hour after a bot registers in the botnet.

Threat name	Detection	Regions attacked
Grandoreiro	2017	Latin America, Europe, USA

This malware has been known since 2017. Since April 2020, there has been a rise in its distribution against the backdrop of the COVID-19 pandemic. In 2021, it was found that the malware was distributed disguised as a legitimate Spotify installer.

Below is a list of targets from the banking Trojan's configuration files analyzed by Group-IB specialists:

Banco do Brasil
Santander
Caixa
Banco Safra
Banco do Nordeste
Sicredi
Agibank
Bradesco
Banorte
Citibanamex
Scotiabank
Bankinter
BBVA
Liberbank
ACTIVOBANK
NOVO BANCO
Banco Azteca
Cecabank
HSBC UK
Natwest
Barclays UK
Banco Estado
Citi Private Bank
Commerzbank
Deutsche bank
EVO Banco
MicroBank
MiBanco

In Q2 2021, Binance was detected in the list of targets; in addition, Eset specialists found that the Trojan had started attacking Belgium and the US.

Threat name	Detection	Regions attacked
Javali/Ousaban	2017	Latin America

This banking Trojan emerged in 2017. It targets banking customers and cryptocurrency owners in Brazil and Mexico.

Below is an up-to-date list of targets:

Banco do Brasil
Banco Bradesco
Santander
Banco Sicredi
BRB Banknet
Banco Inter
Banese
Banco MUFG Brasil S.A.
Banco ABC Brasil

Banco Daycoval
Banco Mercantil
Banco Paulitsa
Banco Safra
Caixa
Banco BMG

As for interesting updates, it is worth mentioning that the Trojan uses a legitimate executable from the Avira antivirus as an injector to avoid being detected.

Threat name	Detection	Regions attacked
Guildma (Astaroth)	2017	Brazil Colombia Ecuador

This Trojan was discovered in 2017. In the second half of 2019, it started attacking users mostly in Brazil. At the height of the pandemic, it was distributed primarily through COVID-19–related email spam. Later, the mailouts were disguised as banking related. In addition to Brazil, in Q2 2021 the Trojan attacked targets in Ecuador and Colombia.

Threat name	Detection	Regions attacked
SilentBuilder (EtterSilent)	June 2020	Global

This is a builder for creating malicious MS Office documents; it is sold on underground resources by a threat actor with the username AsHkERE. At the moment, two vulnerabilities are included: CVE-2017-11882 and 2018-0802. The product is currently very popular and is used by many threat actors.

Ransomware

Threat name	Detection	Regions attacked
Babuk	January 2021	Southern Africa UK Sweden Spain USA Canada Japan Italy Switzerland

In June, the owner of the Babuk affiliate program changed. In April–June, the following companies were attacked:

Phoenix Mecano
RAB Lighting
Cambiaso Risso Shipping Agency Srl
Carlisle Companies
Metropolitan Police Department
Unitex Textile Rental Services
The Centennial School District
YAMABIKO
FCI Constructors
Simon Peragine Smith & Redfearn
Cosmetica Laboratories
DT Engineering Press
Phone House
Mankato Ford
Marietton Développement
Vincle
Zambon Group SpA
C. Watkins Plumbing
Vivida Assistans
Gijima Holdings Limited
PSU Technology

Threat name	Detection	Regions attacked
Prometheus	April 2021	Global

Below is a list of companies attacked in Q2:
O Consulting
Microntel S.p.A
Ghana National Gas
Metalgráfica Cearense
Dinkhauser Kartonagen
Sprink
Hume Cement Sdn Bhd
Coca-Cola Embonor
SENATOR PRESS LIMITED

Medicar
Agricola Cerro Prieto
Paraty Capital
EHC Biel Holding AG
Bill Hotz & Associates
J&S Packaging
Seguros Futuro A.C. de R.L.
Transcargo
Arca Assurances
AQP EXPRESS CARGO SAC
Despretz
Tulsa Cardiovascular Center of Excellence
Balade Farms Food Industries / Grako
Sullestad
Archus
Våpensmia AS
Hotel Nyack
ACL CONSTRUCTION
Bhavna
A-1 Machine Manufacturing Inc
Labet
Hasgoe
Elmich
Aero-Space Computer Supplies
Sincor-SP
Chilli Beans
Master Publicidade Ltda
ADG SARDA SRL
Service Gel Srl
Factoring Baninter
Agencia de Aduana Juan León
Grúas & Equipos Cruz del Sur

Threat name	Detection	Regions attacked
DarkSide	November 2020	USA Guernsey Southern Africa UK Netherlands Brazil France Italy

In April–June, the following companies were attacked:

Condor Ferries
TSF Sportswear
Supabets Gaming Group
Hunt and Walsh
The Paslin Company

LONDONMETRIC PROPERTY PLC
Hitec Power Protection
Baker & Taylor
BTU International, Inc.
Southern Siding & Window Company
Moura
Dixie Group, Inc.
Carolina Eastern
Smile Brands
Bock and Hatch
I&H Brown Limited
Colonial Pipeline
Imagetec L.P.
HELI-UNION
All American Asphalt
Valvitalia SpA
Irving Materials, Inc.

Threat name	Detection	Regions attacked
Cl0p Ransomware	February 2019	USA India Canada

Below is a full list of companies attacked in April–June 2021:
FOODLAND
BOUTINEXPRESS
Resources for the Future
Aurobindo
Utilitytrailer
Kss architects llp
Sgs-law
Valley truck & tractor

Threat name	Detection	Regions attacked
Conti	February 2020	Colombia USA France Canada Austria UK Italy India Germany South Korea Bangladesh Ireland Australia

		Indonesia Dominican Republic

Below is a full list of companies attacked in April–June 2021:
CODIFER S.A.S
D.A. Blodgett St. John's
FE Moran Security Solutions
Klenda Austerman LLC
cross city church
groupe-upperside
Titanium Industries Inc
Comfort Keepers
CAVENDERS
Hensley Beverage Company
Broward County Public Schools
IPSEN
The Village Vets
Capmatic
OpTech Staffing Solutions
Matco-Norca
Edifice General Contractors
Citizens Of Humanity
Kaleidoscope Charter School
DirickX
Complete Automation
DDSG Logistics
Bauder Roofing Solutions
Flaghouse
Bertucci
Filtertek
Precision Terminal Logistics
C.E.E. Schisler Packaging Solutions
Brown Strauss Steel
Options Greathire Ltd
Readie Construction Ltd
PNGC Power
Interfel Corp
Plimpton and Hills Corp
Ford Meter Box
Cairn Capital
HumanWare
Apperton
HW Fisher
aspire inc
SpecPage
TRACTOR CENTRAL
Jacquet Metals Group
Execu Search Group
Travers Tool Co Inc
MISSION IMPRINTABLES

Wizie
PCH International
Bee County Texas
Tasman Butchers
Intermountain Farmers Association
Waikato District Health Board
Riwega S.R.L.
AZ INVESTIGATION
ARWORLD
Mauffrey Group
Transports P. Fatton Inc.
Seifert Logistics Group
MOSS BROS GROUP
Loudoun Mutual Insurance Company
LG CNS
RIB GROUP
DigiCon Technologies Limited
Hentzen Coatings, Inc.
HBD Industries, Inc.
Finolex Cables Ltd.

empire physicians Medical Group
B.P. MITCHELL HAULAGE CONTRACTORS LIMITED
Michael Stevens Interests, Inc.
Vendrig Holding B.V.
Cairns Marine
TURLA SRL
Birtcher Anderson & Davis Associates, Inc.
Cable Color S.A. de C.V.
PT. Realta Chakradarma
TELCAL srl
Sanger & Altgelt Insurance Agents
RPE CONTRACTING
Ireland's Health Service Executive
Electronic Environments Co. LLC
MHA MacIntyre Hudson
ResCon Group
Frank G. Love Envelopes, Inc.
PT. Realta Chakradarma
Bartec Gmbh
Ash Industries, Inc.
Creative Liquid Coatings, Inc
STAM
Moor Park High School
Technical University of Berlin
Funbreak
SEVES Group SpA
BVA Group
Pure Power Technologies
DSD PARTNERS
Antwerp Local Schools
East Texas Alarm
Pure Power Technologies

Temmel Logistik Center
National Louis University
Southwest Recovery Services, LLC
Xpressdocs
La Innovacion
Birmingham Barons
King's Seafood Company
University of Corboda
Nissin International Transport U.S.A., Inc.
Strongco
Thomas Westcott
A&A MECHANICAL
PLURIPHARMA SRL
TPI Corporation
Stride Tool
DSD PARTNERS
eCapital
The Brock Group
Cerfrance Côtes d'Armor
Groupe ISERBA
Sunsations Inc.
BRANGEON Groupe
Vogel Heating & Cooling
Contrast Lighting
Au Forum Du Batiment SAS
Ascenz
Sunsations Inc.
Maître Prunille
Groupe Traon Industrie Development
Windmill Health Products
Voltalia
Uniware Systems
City of Tulsa
Goetze Dental
USI
Cerfrance Côtes d
Proponent
The Waterloo Networking Company
Southern Eagle Distributing
Cambium Inc
Scott Felder Homes
Lareau Courtiers d’assurances
FNA GROUP
KOMPAN A/S
Grupo Herdez, S.A.B. de C.V. Holding Companies
Sleep Outfitters
Engineered Specialty Products, Inc
Nickerson Insurance Services, Inc
Perfume Worldwide Inc.
JAMAC FROZEN FOODS
Concept Building Services
Fischer Homes

DAVACO Inc
Dynamic NC

Threat name	Detection	Regions attacked
DoppelPaymer	June 2019	USA Italy India Canada

Below is a list of companies attacked in April–June:
Diversified Plastics Corporation
Gamma Spa
Briggs Corporation
National Public Seating
Jacobsen Construction Co., Inc.
PVR Cinemas
EMO Trans
Pavages Maska Inc
Loma Systems - A Division of ITW

Threat name	Detection	Regions attacked
Ragnarok	January 2020	Romania Italy Canada Bolivia USA

Below is a full list of companies attacked in April–June 2021:
OMNIDECOR SRL
NO RAG FELICE & FIGLIO SPA
CDN Controls ltd
Moba-automation
Bolivia Petróleo y gas Consultores y Servicios S.R.L.
Porter Ramsay LLP
Kingsdale Advisors

Threat name	Detection	Regions attacked
Nefilim	March 2020	USA Mexico Italy Canada

Below is a full list of companies attacked in April–June 2021:
Colliers International Group Inc
BEIJER REF ITALY SRL
Charm Sciences, Inc
Placon Corp.
GNP Seguros
Grimmway Enterprises, Inc
Spirit Airlines, Inc
Vitro, S.A.B. de C.V.
Atlanta Allergy & Asthma
Elliott Group
Cascade Engineering, Inc.
Unitex Textile Rental Services
Elliott Group

Threat name	Detection	Regions attacked
Avaddon	June 2019	Global

Below is a full list of companies attacked in April–June 2021:
ACER FINANCE
ULTRACEUTICALS PTY LIMITED
PT Angkasa Pura I
Coindu
Henry Oil & Gas
DOCTUM PHARMACEUTICAL K. T. YIOKARIS & CO S.A.
MEGAPOLIS HOLDINGS (OVERSEAS) LIMITED
SL Corporation
Letton Percival
AXA Group
EVGA
Vistex
Cube Audit Ltd
FEBANCOLOMBIA
Solvere LLC
RINGSPANN GmbH
JetSJ
Rate Rabbit Inc
360 InStore
Maryan beachwear group GmbH
Halwani Bros Ltd
PKMK law&finance s.r.o
Ballas Capital Limited
Inventec Appliances Corp
Buckeye International Inc
LE VOLCAN
Syndex
Accounts IQ

Johann Kupp GmbH & Co. KG
Imperial Printing and Paper Box Mfg
Servilex Advocaten
Carlos Federspiel & Co SA
AIM Financial Corporation Ltd
Sessions Payroll Management Inc
Al-Arfaj Group
Loewe Technology GmbH
Saigon Cargo Service Corporation
TEC EPM GmbH
Pronosticos Deportivos
JFA Construction LLC
Tri-Metal Fabricators
JM ROSSA SA
Forbes Hare
WorldUnion
Hupac Intermodal Italia Srl
BRIDGEWAY SENIOR HEALTHCARE
MundoFertil
Monterey Bay Air Resources District
National AIDS Control Council
BEE LINE LOGISTICS, INC
Somerset ISD
Steel Art Signs Corp.
ANLEC R&D
VAUGHN CONCRETE PRODUCTS, INC
The Capital Medical Center
BRIDGEWAY SENIOR HEALTHCARE
Zhuhai Languan Electronic Technology Co., Ltd
JFC International (Europe)
Brown Robert LLP
KOE
SVI ASSURANCES
FUTURIMPLANTS
FBL Advogados
Payzant Building Products Ltd
International Longshore & Warehouse Union
Basque Center for Applied Mathematics-BCAM
Schneider & Branch
KEITH MACHINERY CORP.
Intensive Care On-Line Network , Inc
Sky Leasing, LLC
Groupe Qualinet Inc.
Mikro Trading
Garvin Promotion Group, LLC
Grand Power Systems
Marolles-en-Brie
Dade City Florida
UNIVERSAL ACCOUNTING SERVICES INC
Omni Manufacturing, Inc
CASHMAG.
Oritani - Valley Bank

M&J Evans Construction

Threat name	Detection	Regions attacked
RansomExx	March 2020	Spain Germany Canada Argentine

Below is a full list of companies attacked in April–June 2021:
AYUNTAMIENTO DE CASTELLON DE LA PLANA
Nobiskrug GmbH
Samvardhana Motherson Peguform
Wallace & Carey
STEMCOR
Universal Assistance S.A.

Threat name	Detection	Regions attacked
Mount Locker	July 2020	USA Japan Italy

Below is a full list of companies attacked in April–June 2021:
Eduro Healthcare, LLC
Rogers Engineering & Manufacturing Co., Inc.
Curbell, Inc.
Von Drehle Corporation
HOYA Corporation
Southwest KIA
Pezzutti Group
CREST Hotel & Suites
StoneGate Senior Living
Valley Transportation Authority
InTown Suite

Threat name	Detection	Regions attacked
REvil	April 2019	India UK USA France Canada Fiji Sweden

		Italy Japan Australia Germany Mexico Spain China Brazil Turkey

Below is a full list of companies attacked in April–June 2021:
Sol Oriens
Tata Steel GROUP
Harris Federation
Benetech, Inc.
Weiland Trucking Co., Inc.
Maestri Murrell Commercial Real Estate
Honeywell International Inc.
MBA Group LTD
NorthWest , Insuranse Services
Tristate Midstream
E. & J. Gallo Winery
Fultz Maddox Dickens
Varner & Brandt LLP
Pierre Fabre Group
Universal Group Inc.
EMC, Electric Motor and Contracting Co., Inc .
Fonds Finanz
Oré Peinture
ReppertFactor, LLC.
Harold Marcus Ltd.
Call Assist Ltd
Government administration of Fiji
Habia Cable
Mipharm
SOUTHERN ASPHALT
Treehouse hotels
Kajima corp
Thomas Concrete Group
JHK Legal
Galon Insurance
Amfine Chemical Corporation
Lydall Inc.
KEYENCE DEUTSCHLAND GmbH
ASARCO LLC
Lionco
Vard Group AS
BROWN FORMAN CORPOTAION
Brooks International
NEDA USA
Symbotic LLC

Actuaries and Associates
Kenneth Cole Productions
Jnbs
Ehalc
HYMAN GROUP COMPANIES
ARAFMI
Kenneth Copeland
ANSA McAL
Dailry Farm
CivicSmart
Strategic Sites
GOODMANMINTZ
M J Payne Ltd
Adif
Peter Müller GARTENGESTALTUNG GmbH
Thackray Williams LLP Solicitors
SPEC Inc
GDS Gesellschaft für Datenverarbeitungssysteme
E. & J. Gallo Winery
Apex America
Allen, Dyer, Doppelt, & Gilchrist, P.A.
Betenbough Homes
CEC Vibration Products
ENPOL LLC
Iaffaldano, Shaw & Young LLP
Agile Property Holdings
HUBER+SUHNER
Möbelstadt Sommerlad
Gosiger
GRAYSONS SOLICITORS
Citroen Wells
Royal Resorts
JBS
Hartz Mountain Industries
Fujifilm
Law Offices of Michael B. Brehne, P.A
Aspire/SOL/Willson/Sjk/Tendriade
ESD Dienstleistungs Gruppe
Arnoff Moving & Storage
Macpherson Kelley Lawyers
Invenergy
Feedback Technology Corp.
WestCongress Insurance Services LLC
Whittlesey & Hadley
BridgePoint Financial Services
PM Law Solicitors
Moore Stephens Cape Town
HAAI GmbH
Dicky Smith & Co Inc
Canad Inns.
The Smith & Wollensky Restaurant Group, Inc.
French Connection

VP Supply Corp
Trasporti Internazionali Transmec s.p.a.
Malcolm C Foy & Co Limited
Grupo Fleury
Primo Water
Transform SR Brands, LLC
University Medical Center of Southern Nevada
Asfaltproductienijmegen
CYMZ
Vic Pharma Industry and Trade Ltd.
Masmovil ibercom SA
NERO INDUSTRIES

Threat name	Detection	Regions attacked
Cuba	November 2019	USA Germany

Below is a full list of companies attacked in April–June 2021:
Megaforce
Innovairre

Threat name	Detection	Regions attacked
Ragnar Locker	December 2019	USA Netherlands Germany Taiwan

Below is a full list of companies attacked in April–June 2021:
Webhelp's company - XtraSource
Ludwig Pfeiffer
ADATA
Software company Xoriant

State-sponsored APTs

APT name	Regions attacked	Operation start
Kimsuky	South Korea	December 2020

In its recent attacks, Kimsuky disguised itself as a monthly security magazine by KIMA (Korea Institute for Military Affairs). It was discovered that the malicious content was a structure for downloading additional files by accessing an "External External Connection Address" written in an XML file inside the document.

Normally distributed documents are provided in PDF format. Recently, a large number of malicious Word documents containing documents related to North Korea have been circulating, and it is highly likely that they were sent to recipients who perform North Korean-related tasks.

Another attack involved a decoy document called "외교부 가판 2021-05-07" (translates as "Ministry of Foreign Affairs Edition 2021-05-07"), which indicates that it has been designed to target the Ministry of Foreign Affairs of South Korea. Other targets related to the Korean government include:

- Ministry of Foreign Affairs, Republic of Korea 1st Secretary
- Ministry of Foreign Affairs, Republic of Korea 2nd Secretary
- Trade Minister
- Deputy Consul General at Korean Consulate General in Hong Kong
- International Atomic Energy Agency (IAEA) Nuclear Security Officer
- Nuclear Security Officer Ambassador of the Embassy of Sri Lanka to the State
- Ministry of Foreign Affairs and Trade counselor

The group has the capability to set up a phishing infrastructure to mimic well-known websites and trick victims to enter their credentials. This is one of the main methods used by this actor to collect email addresses that will later be used to send spear-phishing emails.

The threat actors added the Mobile_detect and Anti_IPs modules to be able to detect mobile devices and adjust the view based on that. This phishing model has the capability to show phishing pages in English or Korean based on the parameter value received from the phishing email. This model has been deployed by Kimsuky to target not only Korean speaking victims but also English speakers.

The group used Twitter accounts to find and monitor its targets to prepare well-crafted spear-phishing emails.

Kimsuky reuses some of its phishing infrastructure for its command-and-control communications. In their most recent attack against the South Korean government, the group reused an infrastructure that had been used to host their phishing websites for AppleSeed backdoor C&C communications. Besides using the AppleSeed backdoor to target Windows users, the threat actors also used an Android backdoor to target Android users. The Android backdoor can be considered as the mobile variant of the AppleSeed backdoor.

AppleSeed can:

- Perform keylogging
- Take screenshots
- Collect data from removable media
- Look for .txt, .ppt, .hwp, .pdf, and .doc files in the Desktop, Documents, Downloads and AppData\Local\Microsoft\Windows\INetCache\IE directories and archive them to be ready to be exfiltrated to the server

In addition, South Korean officials said that hackers believed to be operating out of North Korea had breached the internal network of the South Korean Atomic Energy Research Institute (KAERI), a government organization that conducts research on nuclear power and nuclear fuel technology.

In a press conference, a KAERI spokesperson said the intrusion took place on May 14 through a vulnerability in a virtual private network (VPN) server. Thirteen different IP addresses were seen abusing the vulnerability and accessing the organization's internal network.

One of these IP addresses was linked to an attack infrastructure used by Kimsuky, a North Korean cyber-espionage group.

Kimsuky (also known as Velvet Chollima and Thallium) is a hacker group believed to be based in North Korea. The group has been actively attacking entities in the South Korean territory since 2010 but has lately been expanding the geographical scope of their attacks.

APT name	Regions attacked	Operation start
Cycldek	Vietnam, Central Asia, Thailand	June 2020

Security experts observed a new malicious campaign between June 2020 and January 2021. Dozens of organizations were affected; 80% of them are based in Vietnam and belong to the government or military sector or are related to the health, diplomacy, education or political verticals. The experts also identified occasional targets in Central Asia and Thailand. With low confidence, the activities are linked to the Chinese group Cycldek.

As part of an attack against a Vietnamese organization, a legitimate component from Microsoft Outlook was abused to load a DLL that would run a shellcode that was acting as a loader for the FoundCore RAT. Once deployed, the malware would start four processes: one to establish persistence as a service, the second to hide the first process, the third to prevent access to the malicious file, and the fourth to establish connection to the command and control (C&C) server.

FoundCore provides the threat actors with full control over the victim machine. The malware includes support for a variety of commands, allowing for file system manipulation, process manipulation, execution of arbitrary commands, and screenshot grabbing. Other malware delivered as part of the attacks are DropPhone and CoreLoader.

DropPhone launches sdclt.exe, then collects environment information from the victim machine and sends it to DropBox. CoreLoader is a simple shellcode loader which performs anti-analysis and loads additional code from a file named "WsmRes.xsl."

Cycldek (also known as Goblin Panda and Conimes) is a threat group that has been active for the most part of the past decade and has historically had motives related to information theft and espionage aligned with Chinese interests. The group's targets are primarily military, energy, and government organizations located in South/South-East Asia with a focus on Vietnam.

APT name	Regions attacked	Operation start
APT-C-23	Palestine, Syria, Turkey, Iraq, Lebanon, Libya	August 2019

Facebook busted the operations of two state-sponsored threat groups operating out of Palestine. The threat actors abused its platform to distribute malware with the aim of espionage.

The social media giant attributed the attacks to a network connected to the Preventive Security Service (PSS), which is part of the security apparatus of the State of Palestine, and another threat actor known as

Arid Viper (aka Desert Falcon and APT-C-23), the latter is alleged to be connected to the cyber arm of Hamas.

The two digital espionage campaigns took place in 2019 and 2020. The PSS primarily targeted domestic audiences; the other cluster targeted audiences in the Palestinian territories and Syria and to a lesser extent Turkey, Iraq, Lebanon and Libya.

The PSS used custom-built Android malware that was disguised as secure chat applications to stealthily capture device metadata, capture keystrokes, and upload the data to Firebase. In addition, the group deployed another Android malware called SpyNote, which came with the ability to monitor calls and remotely access compromised phones.

This group used fake and compromised accounts to create fictitious personas, often posing as young women, and also as supporters of Hamas, Fatah, various military groups, journalists, and activists with the aim to build relationships with the targets and guide them toward phishing pages and other malicious websites.

In their targeted campaigns, Arid Viper used new custom iOS surveillanceware dubbed Phenakite, capable of stealing sensitive user data from iPhones without jailbreaking the devices prior to the compromise. Phenakite was delivered to users in the form of a fully functional but trojanized chat application named MagicSmile. The group also maintained 179 domains, which were used to host malware or acted as C&C servers.

APT-C-23 (also known as AridViper, Desert Falcon, Desert Scorpion, DHS, Two-tailed Scorpion, and The Big Bang APT) is a politically motivated threat group that mainly targets Palestine government officials, diplomats, and other officials with the aim of obtaining information (espionage).

APT name	Regions attacked	Operation start
Gaza Cybergang	Middle East	2021

Security experts say that Gaza Cybergang conducted attacks on a weekly basis throughout early 2021 before abruptly stopping in March for a two-month hiatus. The campaign resumed in early June 2021 with continued use of malware dubbed LastConn. Researchers assess with high confidence that LastConn is an updated version of the SharpStage malware first reported in December 2020.

In June campaigns, Gaza Cybergang leveraged a PDF attachment with one or multiple geofenced URLs leading to password-protected archives that contained the malware. The email and the PDF are typically both written in Arabic, and the lure is usually based on a geopolitical topic impacting the Middle East, especially the Gaza conflict.

The hackers first check whether the source IP address belongs to the targeted countries in the Middle East. If the source IP address does not align with the target group, the URL may redirect the recipient to a benign decoy website, typically an Arabic language news website.

Another initial access vector in the hacker's 2021 arsenal observed in February is the use of Google Apps Script URLs directly inside the spear-phishing email. Google Apps Script is a development platform based on JavaScript that helps create both standalone web apps and powerful extensions to various elements of the Google Apps software-as-a-service ecosystem.

LastConn malware is specifically targeted at computers with an Arabic language pack installed to ensure it only infects specific targets. It uses Dropbox for all C&C capabilities and infrastructure.

The main commands available for LastConn include:

- DFileDrop — download and execute a file hosted on the malware's Dropbox
- DFromUrl — download and execute a file hosted at a URL

- Cmd — execute a cmd.exe command and send the results back to the malware's Dropbox via the file "txt_ShellCode"
- Powershell — similar to Cmd, but for Powershell
- WMIC — similar to Cmd, but for WMIC
- ListFile — get specified file listing and send the results back to the malware's Dropbox via the file "txt_ListFile"
- UploadFiles — create a folder on the malware's Dropbox and upload specified files to it
- Screenshot — take a screenshot and upload to the malware's Dropbox
- GetIP — get IP address via hxxps://api.ipify\.org and upload to the malware's Dropbox

Gaza Cybergang (also known as Molerats and TA402) has been active since 2012 and has been mainly targeting government agencies in the MENA region. The attackers use phishing emails, paste sites hosting malware stages, social engineering methods, and various RATs. The group's goal is to collect intelligence data.

APT name	Regions attacked	Operation start
Unknown hackers attack Azerbaijan	Azerbaijan	2021

The document lure involved in the malicious activity in question is written in Azerbaijani and talks about a "National Security and Scientific" conference that will be held in Azerbaijan in 2021. The malicious document contains an obfuscated macro. The attackers inserted random characters within meaningful names to obfuscate the names of functions and variables. Here are some of the examples:

- AddArg _OACZT_20210214_115603_xokkn_ uments29 -> AddArguments29
- zi xokkn pPath -> zipPath
- tes OACZT tcustomdir abcdefghijklmnopqrstuvwxyz ect _OACZT_20210214_115603_xokkn_ ory -> testcustomdirectory

The threat actors used an interesting steganographic method. In one stage, a document copy is created and extracted, then the ExtractFromPng function is called to extract an embedded object from a .png file. This function calls itself recursively to read all chunk identifications within the .png image until it reaches the "puNk" chunk identification which is a chunk that has an embedded .zip file. After finding the chunk, it extracts and writes it into "fairfax.zip."

Then, "fairfax.zip" is extracted into the %APPDATA%\vstelmetry directory. It contains an executable file ("Fairfax.exe") as well as a batch file ("runner.bat").

FairFax.exe is a .Net RAT developed using the TAP (Task Asynchronous Programming) model. This model provides an abstraction over asynchronous code. In this model, each functionality can be defined as a task and will be executed based on external resource allocation and when other tasks are completed.

The RAT has three main capabilities:

- Downloading files
- Uploading files
- Taking screenshots

All communications with the server are AES encrypted and Base64 encoded. It also has the capability to make itself persistent by creating a VBS file and adding it to Scheduled Tasks.

APT name	Regions attacked	Operation start
Machete	Argentina, Venezuela, Latin America	2020

The Machete threat group continues its attacks against targets in Latin America; in particular, several decoys attributed to the group were uploaded to VirusTotal from Argentina.

The C&C servers were the same as the ones used in late 2020. The hackers started using the LokiRat Trojan, which was freely available on Brazilian dark-web forums as well as in online code repositories.

Interestingly, the code and infrastructure contain Russian-language strings, although these strings are seemingly arbitrary and not suggestive of Russian origins. For example, the code authors changed one of the HTTP request fields from "Black_Lightning" to "Utopiya_Nyusha_Maksim" suggesting this is a change that happened after the code had been developed and not an artifact from the developers. Security experts believe that the Russian-language artifacts are likely the threat actor's attempt to cause misattribution.

Most of the core functionality that LokiRat provides has been in the Machete framework for many years, but the LokiRat code gives the threat actors a couple of new benefits. For instance, it expands on Machete's capabilities available to the operators by including functions to:

- Extract browser passwords from Chrome and FireFox
- Capture keystrokes
- Take screenshots
- Employ self-cleanup by deleting LokitRat and auxiliary Python files
- Create, modify, and delete files

The Spanish-speaking APT group Machete (also known as ATK 97, TAG-NS1, and APT-C-43) has been active since 2010. The group's targets are the military, embassies and government entities in Latin America.

APT name	Regions attacked	Operation start
Gamaredon	Ukraine	January 2021

In April 2021, Group-IB specialists discovered new malicious activity and a tool we dubbed Gamaredon.Stealer. We believe that this Trojan may have evolved from Pteranodon and USBStealer. The malware emerged no later than in January 2021 and has already had several changes. Its primary aim is to steal files from logical and USB drives; it can also take screenshots.

Later in April we discovered new decoy documents that targeted Ukraine's military sector.

The threat actors used a very unusual technique for resolving domains' IP addresses: the application first resolves an IP address using the ping command. From the command result, the application extracts the IP address of the domain and performs an HTTP request to the IP address instead of the domain itself.

Gamaredon Group (also known as Primitive Bear and SectorC08) is presumably a Russian threat group active since at least 2013. The group's aim is to spy on Ukrainian government officials, the military, diplomats, law enforcers, and, in recent campaigns, journalists.

APT name	Regions attacked	Operation start

APT5	USA, Europe	August 2020

In Q2 2021, malicious activity by UNC2630 against US Defense Industrial base (DIB) networks came to light. An investigation by Pulse Secure determined that a combination of prior vulnerabilities and a previously unknown vulnerability (zero day) discovered in Pulse Connect Secure gateways in April 2021, CVE-2021-22893, are responsible for the initial infection vector.

Security experts observed UNC2630 harvesting credentials from various Pulse Secure VPN login flows, which ultimately allowed the actor to use legitimate account credentials to move laterally into the affected environments. In order to maintain persistence to the compromised networks, the actor utilized legitimate, but modified, Pulse Secure binaries and scripts on the VPN appliance.

UNC2630's combination of infrastructure, tools, and on-network behavior appear to be unique, and the experts have not observed them during any other campaigns or at any other engagement. Despite these new tools and infrastructure, Mandiant analysts noted strong similarities to historic intrusions dating back to 2014 and 2015 and conducted by the Chinese espionage actor APT5.

Further investigation revealed that organizations across the defense, government, high tech, transportation, and financial sectors in the U.S. and Europe were affected. To conduct attacks, the group used a total of 12 unique tools, which perform standard actions such as harvesting credentials and sensitive system data, allowing arbitrary file execution, and removing evidence.

APT5 (also known as Manganese) has been active since 2007. Researchers say the hackers appear to be a large threat group that consists of several subgroups, often with distinct tactics and infrastructure. The threat actors are believed to be sponsored by the Chinese government. APT5 has targeted or breached organizations across multiple industries, but its focus appears to be on telecommunications and technology companies, especially information about satellite communications.

APT name	Regions attacked	Operation start
UNC1151	Lithuania, Latvia, Poland, Germany, Ukraine, Hungary, France, Kuwait	2017

In July 2020, Mandiant released a public report detailing an ongoing cyber-enabled influence campaign named Ghostwriter, which primarily targets audiences in Lithuania, Latvia and Poland and promotes narratives critical of the North Atlantic Treaty Organization's (NATO) presence in Eastern Europe.

The researchers found that Ghostwriter activity had expanded. For example, several recent operations have heavily leveraged the compromised social media accounts of Polish officials to publish content seemingly intended to create domestic political disruption in Poland rather than foment distrust of NATO. These operations, conducted in Polish and English, appear to have largely not relied on the dissemination vectors that have typically been observed with previous Ghostwriter activity, such as website compromises, spoofed emails, or posts from inauthentic personas.

The obtained evidence allows the security specialists to attribute the activity to UNC1151, a suspected state-sponsored cyber espionage actor that engages in credential harvesting and malware campaigns. The security specialists do not associate UNC1151 with any other previously tracked threat groups. Since the start of 2021, UNC1151 has expanded its credential theft activity to target German politicians. This targeting has been publicly reported in the German Tagesschau.

The group was seen conducting targeted mailouts with malicious attachments that led to the installation of the RADIOSTAR, VIDEOKILLER and HALFSHELL Trojans.

APT name	Regions attacked	Operation start
Naikon	South-East Asia	June 2019

Cyber espionage operations conducted by the Chinese APT group Naikon between June 2019 and March 2021 came to light.

The group's targets were military entities in South-East Asia. The hackers' main goals were to persist in compromised systems, collect confidential information, and send it to C&C servers. To do so, the threat actors used two custom backdoors: RainyDay and Nabulae (both have full-fledged RAT functionality).

Naikon (also known as Camerashy and Hellsing) is a threat group that has focused on targets around the South China Sea since 2012. The group has been linked to the Chinese People's Liberation Army's (PLA) Chengdu Military Region Second Technical Reconnaissance Bureau (Military Unit Cover Designator 78020).

APT name	Regions attacked	Operation start
Operation TunnelSnake	South Asia, South-East Asia, Africa	2018

A threat group of unknown origin has been using a new rootkit in attacks against Windows systems. Security experts named the campaign TunnelSnake and believe it has been active since at least 2018.

Malware called Moriya is a backdoor that enables threat actors to intercept network traffic and send commands to compromised nodes. Moriya allowed the TunnelSnake operators to capture and analyze incoming network traffic from the Windows kernel's address space, where typically only privileged and trusted code runs.

The way the backdoor received commands in the form of custom-crafted packets hidden within the victims' network traffic, without needing to reach out to a C&C server, further added to the operation's stealth showing the threat actor's focus on evading detection.

The specialists do not name the group behind the TunnelSnake campaign but say that it is likely a Chinese-speaking one.

The attackers also deployed additional tools like China Chopper, BOUNCER, Termite, and Earthworm, during the post-exploitation stage on the compromised systems. This action enabled them to laterally move on the network after finding new vulnerable hosts on the victims' networks.

The attacks were highly targeted and delivered to less than 10 victims around the world. The most prominent victims are two large regional diplomatic organizations in South-East Asia and Africa, while all the others were victims in South Asia.

APT name	Regions attacked	Operation start
Transparent Tribe	India, Pakistan, Iraq, Afghanistan	2019

Transparent Tribe continues to create fake domains imitating those of legitimate military and defense organizations as the main element of its operations. While military and defense personnel remain the primary targets of the group, Transparent Tribe has been increasingly targeting diplomatic entities,

defense contractors, research organizations, and conference participants, which indicates that the group has been expanding the scope of its targets.

Transparent Tribe's tactics, techniques, and procedures have barely changed since 2020, but the group continues to introduce new lures in its toolset. The variety of decoys that Transparent Tribe uses indicates that the group still relies on social engineering as the main component of its activities.

In the end, Crimson RAT was installed on victim machines.

Transparent Tribe (also known as APT36, ProjectM, Mythic Leopard, and TEMP.Lapis) is a Pakistani threat group active since 2012. Transparent Tribe carries out cyber espionage operations with the aim of collecting confidential information from India to support Pakistani military and diplomatic interests.

APT name	Regions attacked	Operation start
Attack on a water treatment facility	USA	2021

In February, unknown hackers breached a water treatment facility in Pinellas County, Florida, which treats water for about 15,000 people. The threat actors tried to increase the amount of sodium hydroxide in the water by more than 100 times.

The facility where the incident occurred services the town of Oldsmar, which is about 25 kilometers from Tampa, the third most populated city in Florida. The facility's network was configured in a way that made it possible for authorized users to remotely manage the operation of the facility in case of emergency or technical failure.

The hackers first connected to the system on Friday, February 5, at 8 AM, which an operator at the facility noticed, but did not take seriously because the head of the facility regularly connected to the system remotely. A few hours later, at 1:30 PM, the threat actors gained access again, this time they tried to change parameters in the equipment, namely, set the amount of sodium hydroxide in the water to 11,100 parts-per-million (ppm) while the normal level is 100 ppm. The threat actors were in the system for about three to five minutes. The operator noticed it, informed their employer, and brough the parameter back to the original level. The hackers left the system.

Security researchers discovered that a Florida utility contractor hosted malicious code on its website, which is known as a watering hole attack. This malicious code seemingly targeted water utilities and was visited by a browser from the city of Oldsmar on the day of the breach.

A hacker exploited a vulnerable WordPress plugin to host the malicious code, which collected website visitors' fingerprints including the operating system and CPU, browser, touchpoints, and video card display adapter details.

The website was infected for 58 days until February 16, 2021.

The code was also found on one other website, DarkTeam Store, an underground online shop. The researchers discovered that DarkTeam Store and the Florida contractor's website were subverted on the same day, December 20, 2020.

The experts believe that the malicious code's purpose was to collect browser fingerprints to then use them in the Tofsee botnet to better simulate real users. It is unclear whether the breach of the contractor's website is connected with the hack at the Oldsmar water treatment facility. It is also unclear why the botnet owner chose that particular website for information collection.

APT name	Regions attacked	Operation start
Attack on a group of Uighurs	Xinjiang, Pakistan, Malaysia, Turkey	2020

During the past year, security experts tracked an ongoing campaign targeting a small group of Uighurs living in Xinjiang and Pakistan. Considerable effort was put into disguising the payloads, whether by creating delivery documents that appear to be originating from the United Nations using up-to-date related themes, or by setting up websites for non-existent organizations claiming to fund charity groups.

During 2020, a fake website served at least two variants of Windows implants: one referred to as WebAssistant, which was available in May 2020, and another called TcahfUpdate, which was available in October 2020.

The threat actor behind this campaign appears to still be active in 2021, with two malicious domains redirecting to the website of a Malaysian government body called the Terengganu Islamic Foundation. This suggests that the threat actor is pursuing additional targets in countries such as Malaysia and Turkey.

Although the security experts were unable to find code or infrastructure similarities to a known threat group, they attribute this activity, with low to medium confidence, to a Chinese-speaking threat actor. When examining malicious macros in the delivery document, the experts noticed that some excerpts of the code were identical to VBA code that appeared in multiple Chinese forums and might have been copied from there directly.

APT name	Regions attacked	Operation start
APT27	Lebanon, Turkey, Kuwait, Qatar, Jordan, Saudi Arabia, UAE, Mongolia, Philippines	2019

An investigation into Operation DRBControl revealed additional tools: an updated SysUpdate malware variant, the Pandora backdoor, and the hidden.sys rootkit.

The operation lasted for 18 months and targeted a Philippine-based gambling company. The primary infection vector was not confirmed, but traces of the exploitation of the Microsoft Exchange vulnerability CVE-2020-0688 were found. Security experts observed how APT27 targeted governments, banks, telecommunication providers, and the energy sector in Lebanon, Turkey, Kuwait, Jordan, Qatar, Saudi Arabia, Bahrain, the UAE, Afghanistan, India, Mongolia, and the Philippines.

Below is the timeline of discovered samples used in the DRBControl campaign:

- July 2019: Operation DRBControl starts
- October 2019: a HyperBro malware sample found
- March 2020: a new sample of Clambling backdoor and a rootkit called Pandora found
- April 2020: the Hidden.sys rootkit found
- October 2020: new HyperBro and Pandora samples found
- December 2020: an updated variant of the SysUpdate malware found
- January 2021: Fast Reverse Proxy (FRP) Linux tool found
- An updated version of the SysUpdate backdoor

In December 2020, a sample belonging to the SysUpdate malware family was discovered.

In the past, SysUpdate was loaded in memory by a known method involving three files, while the recent versions involved five files:

- dlpumgr32.exe — a legitimate file
- DLPPREM32.DLL — a malicious file that loads and decodes DLPPREM32.bin
- DLPPREM32.bin — a shellcode that loads a launcher in memory
- data.res — an encrypted file that is decoded by the launcher and contains two SysUpdate versions (32- and 64-bit)
- config.res — an encrypted file that is decoded by the launcher and contains the SysUpdate configuration

The launcher, added in the updated SysUpdate variant, acts as an installer: it will copy the malware to a fixed place and ensure that it runs during the next boot of the infected host. The updated SysUpdate version is similar to its previous versions; it includes a screenshot feature, file management functions (such as search, delete, move, upload, and download), process and services management, and command execution.

On two occasions (in March and October 2020), the security specialists found a kernel rootkit deployed, which was similar to NDISProxy; it was dubbed Pandora. It was not digitally signed and instead utilized an exploit to bypass Windows Driver Signature Enforcement (DSE) protection and load directly into the system. The rootkit has multiple stages before getting to the actual payload.

In April 2020, the Hidden.sys rootkit was discovered, which was used to hide processes, files, and services. It was taken from a public GitHub repository.

In addition, the security experts found the FRP tool being used on a Linux host. The analyzed FRP tool was a modified version, possibly copied off of Github.
APT27 is a Chinese cybercriminal group known since 2010. The group targets aerospace, government, defense, technology, energy and manufacturing industries. It has recently started actively using ransomware in their attacks, with a focus on financial gain.

APT name	Regions attacked	Operation start
DarkHalo	USA, Europe, Ukraine, UK, Canada, Germany	2020

In April 2021, several new samples of the GoldMax, Sibot and GoldFinder programs of the DarkHalo group were discovered. In addition, a China Chopper webshell server-side component was detected, which had been obfuscated to avoid detection. The webshell was placed on a network with an active GoldMax infection to provide the actors with an alternative method of accessing the network if the GoldMax infection was remediated.

In late April, security researchers discovered a campaign whose start is traced to January 28, 2021, when the first phishing emails were discovered, which leveraged the Google Firebase platform to stage an ISO file containing malicious content while also leveraging this platform to record attributes of those who accessed the URL. This was a reconnaissance stage, in which no delivery of malicious payloads was observed.

In the next evolution of the campaign the mailouts were improved. The threat actors attempted to compromise systems through an HTML file attached to a spear-phishing email. When opened by the targeted user, a JavaScript within the HTML wrote an ISO file to disc and encouraged the target to open it, resulting in the ISO file being mounted much like an external or network drive. From here, a shortcut file (LNK) would execute an accompanying DLL, which would result in Cobalt Strike Beacon executing on the system. Similar spear-phishing campaigns were detected throughout March with several alterations to the accompanying HTML. The threat actors also experimented with redirecting the HTML document to

an ISO, which contained an RTF document, with the malicious Cobalt Strike Beacon DLL encoded within the RTF. In another case, a URL led to a website from where the ISO was distributed.

There were other cases discovered, in which no ISO payload was delivered, but additional profiling of the target device was performed by an actor-controlled web server after a user clicked the link. If the device targeted was an Apple iOS device, the user was redirected to another server under the threat actors' control, where a zero-day exploit for CVE-2021-1879 was served.

In May 2021, the actors dropped the custom .NET implant BoomBox, which reported host-based reconnaissance data to, and downloaded additional payloads from the Dropbox cloud storage platform.

On May 25, 2021, security researchers identified a phishing campaign targeting multiple organizations based in the United States and Europe. Non-governmental organizations (NGOs), research institutions, government agencies, and international agencies were targeted. The phishing emails purported to originate from the US Agency for International Development (USAID) and contained a malicious link that resulted in an ISO file being delivered. The link is used to track user clicks: the threat actors used it to track whether the victim opened the email. When the recipient follows the link, they are redirected to the URL hxxps://usaid[.]theyardservice[.]com/d/[Victim Email]. This network request will initiate a download for the malicious ISO file "ICA-declass.iso" to the victim's system. The ISO file acted as an alternative to standard archives; a PDF decoy, an LNK file, and "Documents.dll" were discovered in it.

If a user opened the LNK file, it would run "Document.dll." It should be noted that nearly all of the metadata had been removed from the LNK file. Typically, LNK files contain timestamps for creation, modification, and access, as well as information about the device on which they were created. "Document.dll" checks registry keys to detect sandboxes. After the checks are passed, the malware deobfuscates a payload, which is executed within the same process. The final payload is CobaltStrike Beacon. After Cobalt Strike has been successfully installed, a secondary DLL payload, dubbed FRESHFIRE, is downloaded. The downloaded malware uses specific attributes on the infected hostname to decrypt and execute data received from a remote C&C server.

Researchers at Microsoft are tracking new activity of DarkHalo, which they say has mostly been unsuccessful, with the majority of the targets not being successfully compromised. At least three unnamed entities, however, have been compromised. The attacks were targeted primarily at IT companies and, to a lesser extent, government and non-governmental organizations, think tanks, and financial services. The activity was largely focused on the US and, to a lesser degree, the UK, Germany, and Canada. A total of 36 countries were targeted.

The threat actors used password-spray and brute-force attacks. The researchers detected information-stealing malware on a machine belonging to one of their customer support agents with access to basic account information for a small number of customers (subscription to Microsoft services, contact details for invoices, services paid by customers, etc.). The threat actors gained access to the machine in the second half of May and used this information to launch attacks as part of their broader campaign. The researchers say the support agents are configured with the minimal set of permissions.

DarkHalo has been active since at least 2019. The group carried out a global supply-chain attack against the customers of SolarWinds by creating a trojanized version of a software update, which was named sunburst.

APT name	Regions attacked	Operation start

APT34	Lebanon	January 2021

In January 2021, APT34 started conducting attacks against organizations in Lebanon. During this campaign, the threat actors sent out a new backdoor called SideTwist and a malicious document imitating a job description. One of the phishing documents sent out was called "Job-Detalis.doc" and was designed as a description of various positions in Ntiva, an IT consulting company based in the US. The decoy contained a malicious macro, which once enabled triggered the full infection flow. The macro performs the following:

- Verification that there is a mouse connected to the PC (Anti-Sandboxing technique)
- Initial fingerprinting of the target device and sending of the information to the C&C server using DNS tunneling
- Dropping the embedded executable (SideTwist) to disk with a .doc extension (later to be renamed to .exe)
- Registering a Windows scheduled task that would launch the executable every X minutes

The threat actors use the publicly available requestbin[.]net DNS tunneling service. This way the attacker-owned infrastructure would not be exposed, in case a sandbox is not able to fully detonate the document. The backdoor's functionality includes downloading and uploading files and executing shell commands. SideTwist does not have any persistence mechanism of its own. Persistence is achieved by ensuring persistence for the first stage through the scheduled task named SystemFailureReporter. Every time SideTwist would launch, it would only execute a single command provided from the C&C server and immediately shut down until it is launched again by the scheduled task.

The backdoor's communication with the C&C server is HTTP based on port 443 with port 80 as fallback. The backdoor uses two different techniques for its outgoing and incoming communications with the C&C server, though in both cases the same encryption algorithm is utilized.

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The threat actors mainly target the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group had targets in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE, and Lebanon.

APT name	Regions attacked	Operation start
APT32	Vietnam	May 2018

In late March 2021, security researchers discovered an ELF file that had full backdoor functionality. It had not been detected by antivirus solutions for at least three years. The backdoor was named RotaJakiro. To remain unnoticed, it uses several encryption algorithms:

- AES to encrypt resource information
- C&C communication involves a combination of AES, XOR, ROTATE encryption and ZLIB compression

RotaJakiro supports a total of 12 functions, three of which are related to the execution of specific plugins. The backdoor's functions can be grouped into the following four categories:

- Reporting device information
- Stealing sensitive information
- File/plugin management (query, download, delete)

- Execution of specific plugins (analysis of plugins is not possible because there is no access to them)

In addition to this sample, three more samples with zero detections on VirusTotal were discovered. The earliest First Seen date is May 16, 2018. The samples have four C&C servers that they communicate with.

All the samples are similar in functionality. They can determine whether the user is root or non-root at run time. After being launched, the malware decrypts the relevant resources using AES and ROTATE for subsequent persistence and establishes communication with the C&C server.

Detailed analysis revealed similarities of the code with a sample for MacOS, which the OceanLotus group used in 2016 and 2017.

Security researchers mention the following similarities:

- Method of creating a C&C session
- Registration packet construction method
- Use of the function rotate()
- Same DWORD-type instruction codes

In addition, the Threat Intelligence & Attribution system detected and marked two out of four domains in this campaign as ones that the OceanLotus group has used since December 2016.

OceanLotus, also known as APT32, APT-C-00, SeaLotus, Sinh Tử Lệnh, Cobalt Kitty, and SectorF01, has been active since late 2009 and is believed to be based in Vietnam. The group has attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the United States. Apart from phishing emails, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
APT41	Taiwan, India	January 2021

In April 2021, the Threat Intelligence & Attribution system detected attacks against Taiwanese and Indian organizations. The campaign was named ColunmTK and with medium to high confidence is attributed to APT41. According to Group-IB specialists, between February 2021 and July 2021, the threat actors attacked organizations such as Air India, Changhua Christian Hospital, TVBS Media, National Development Fund of Taiwan, and Delta Electronics.

Analysis revealed that the threat actors used the Cobalt Strike post-exploitation framework together with mimikatz to extract credentials; they also used BadPotato to escalate local privileges.

In this campaign, the threat actors used the server 185.118.166[.]66, which hosted Cobalt Strike. According to data from the Threat Intelligence & Attribution system, this server had a unique SSL certificate installed, b3038101fd0e8b11c519f739f12c7e9b60234d3b, which had been observed only on seven IP addresses:

IP address	Location	Cert found	Organization
104.224.169[.]214	US	2020.01.13-2020.08.25	IT7 Networks Inc

45.61.136[.]199	US	2020.08.25-2020.08.30	BL Networks
185.118.164[.]198	RU	2020.12.03-2020.13.03	Chelyabinsk-Signal LLC
185.118.166[.]66	RU	2020.12.15-2021.05.18	Chelyabinsk-Signal LLC
149.28.134[.]209	SG	2021.04.24-2021.05.24	Vultr Holdings, LLC
45.144.31[.]31	RU	2021.06.14-2021.06.24	Webhost LLC
193.187.116[.]134	HK	2021.06.18-2021.06.21	Cloudie Limited

Interestingly, two IP addresses from the list (45[.]61[.]136[.]199 and 104.224.169[.]214) were used by APT41 in attacks described by Microsoft and Positive Technologies. In addition, a file called "install.bat" was detected, 49e338c5ae9489556ae8f120a74960f3383381c91b8f03061ee588f6ad97e74c, which was distributed in the **ColunmTK** campaign. **The contents of this file are identical to the file "install.bat" used by APT41 in the *This is not a test* campaign in 2020**.

According to data from the Group-IB Threat Intelligence & Attribution system, six similar Cobalt Strike beacon configurations were observed. One of them contains the following domains for communication with the C&C server:

"C2Server": "help01.softether[.]net,/users/sign_in,work.cloud01[.]tk,/users/sign_in,work.cloud20[.]tk,/users/sign_in,185.118.166[.]205,/users/sign_in".

One of them, cloud01[.]tk, had been detected by security experts earlier. The experts found a payload sample and compared it to APT41's known sample. The comparison revealed that the pattern of receiving WinAPI function addresses is similar, even though the names of these functions are different. In addition, the naming convention of the export functions for both samples is identical.

In light of the connections found, Group-IB researchers attribute the ColunmTK campaign with medium to high confidence to APT41.

APT41 (also known as WICKED SPIDER (PANDA), Winnti Umbrella, BARIUM, LEAD, Blackfly, Suckfly, and GREF) is a Chinese state-sponsored threat group whose goals are cyber espionage and financial gain. The group has been active since at least 2007. APT41 specializes in stealing digital certificates to use them in activities related to stealing user data (cyber espionage) and deploying crypto miners and ransomware on target devices. The group's earlier goals included manipulation of currencies in online games and intellectual property thefts.

APT name	Regions attacked	Operation start

APT28	-	March 2021

In June 2021, security researchers discovered a new piece of malware called SkinnyBoy, which they attribute to APT28 with mid-to-high confidence. The malware was used in attacks targeting military and government institutions.

SkinnyBoy is delivered via a spear-phishing email that contains a Word document with a name relating to an international conference. The Word document contains a macro, which when executed extracts a DLL file acting as a downloader for the SkinnyBoy dropper ("tdp1.exe").

Once on the victim system, the dropper establishes persistence and moves to extract the next payload, which is encoded in Base64. The malicious process decodes the payload and deletes itself after extracting two files:

- C:\Users\%username%\AppData\Local\devtmrn.exe
- C:\Users\%username%\AppData\Local\Microsoft\TerminalServerClient\TermSrvClt.dll

To stay under the radar, the malware never executes the extracted files. Instead, it creates a persistence mechanism on the infected machine, which enables delayed execution of the next stages. It creates a file called "devtmrn.lnk" under the Windows Startup folder, which points to the extracted malware "devtmrn.exe." Once the machine reboots, the execution of the "devtmrn.exe" is triggered.

"TermSrvClt.dll" is the main implant of the infection chain. It exfiltrates information about the infected system and retrieves and launches the final payload. Collecting data involves using the systeminfo.exe and tasklist.exe utilities, which is followed by the extraction of file names in specific locations. The output is concatenated using a fixed structure, which is then sent to the C&C server in Base64 format using a POST request. After transferring the gathered information, the malware contacts the C&C server again in order to retrieve the next payload. The payload received from the server is the final stage of the infection, which supports backdoor functionality. Once received, the payload is stored in the %TEMP% folder, self-injects and executes in memory using the LoadLibrary and GetProcAddress WinAPIs. The downloaded file is then deleted.

APT28 is a Russian-speaking cybercriminal group active since 2004. Most of the group's attacks have targeted political and military organizations, and, to a lesser extent, media outlets and sports organizations.

APT name	Regions attacked	Operation start
Agrius	Israel, UAE, Middle East	2019

Security experts discovered a new Iranian hacker group called Agrius, which has been attacking Israeli targets since at least December 2020. The researchers warn that the hackers intentionally destroy their victims' data, mask such activity as ransomware attacks, and demand a ransom.

During the first stages of an attack, the hackers use virtual private network (VPN) software while accessing public-facing apps or services belonging to their intended victim before attempting an exploit, often through compromised accounts and software vulnerabilities. For example, a vulnerability in FortiOS, tracked as CVE-2018-13379, has been widely used in exploit attempts against targets in Israel. If successful, the threat actors deploy webshells (ASPXSpy), use legitimate tools for credential harvesting and network movement, and deploy malware.

Agrius' toolkit includes Deadwood (also known as Detbosit), a destructive wiper malware strain. Deadwood was linked to attacks against Saudi Arabia during 2019, thought to be the work of APT33.

During attacks, Agrius also drops a custom .NET backdoor called IPsec Helper for persistence and to create a connection with a C&C server. In addition, the group drops a novel .NET wiper dubbed Apostle.

In a recent attack against a state-owned facility in the UAE, Apostle appears to have been improved and modified to contain functional ransomware components. The researchers believe, however, that its main purpose is to destroy data rather than encrypt it for financial gain.

APT name	Regions attacked	Operation start
Chinese hackers attack Russian federal agencies	Russia	2020

It came to light that hackers had conducted targeted attacks against Russia's federal agencies. The attacks were discovered in 2020.

The threat actors used three attack vectors to penetrate the federal agencies' infrastructures:

- Phishing (well crafted for specific government agencies)
- Exploitation of vulnerabilities in public-facing web applications
- Breach of contractors' infrastructures (Trusted Relationship)

Within the perimeter, the hackers collected information about the network and key services. To obtain as much control as possible, they tried to attack infrastructure management systems and the workstations of IT administrators with high access privileges.

After completely compromising the target infrastructure, the hackers aimed to collect confidential information from all sources they were interested in: mail servers, e-document management systems, file servers, and workstations of managers of various levels.

Technical details of the attacks:

- The malware developed by the threat actors to upload collected data used the cloud storage spaces of Russian companies Yandex and Mail.ru Group. The hackers masked their network activity as legitimate utilities, Yandex Disk and Disk-O.
- The hackers had clearly studied how to administer a popular Russian antivirus solution and were able to use its legitimate components to collect additional information about the targeted system.

Group-IB specialists studied a report on the hackers' activities and concluded that Chinese hackers are behind the attacks against Russian federal agencies. BlueTraveller and/or TA428 may be responsible for the attacks.

APT name	Regions attacked	Operation start
ReverseRat — Pakistani hackers' new tool	South and Central Asia	2019

Security experts detected a new remote access Trojan called ReverseRat. Its operators target government and energy organizations in South and Central Asia. In their analysis of this campaign, the specialists found similarities with the tactics, techniques, and procedures used in Operation SideCopy, which was organized by Transparent Tribe, a Pakistani APT, last year. The experts did not say whether the two groups were linked.

ReverseRat was deployed in parallel with an open-source RAT called AllaKore to infect machines and achieve persistence.

In the first phase of the campaign the threat actors sent out URLs pointing to compromised websites to their victims (presumably via email).

When clicked, these links downloaded a .zip file containing a Microsoft shortcut file (.lnk) and a benign PDF file. If invoked by the user, the shortcut file would display a benign PDF file. Meanwhile, the .lnk file surreptitiously retrieved and executed an HTA file (HTML application) from the same compromised website.

The decoy PDF documents referred to organizations and events relevant to India in spring 2021. Some of the decoy documents, or lures, were more generic, making references to COVID-19 vaccines, while others were more targeted toward, for example, the energy sector.

In the next phase of infection, the first HTA file retrieved contained JavaScript code based on a GitHub project called CactusTorch. This project was designed to help launch a .NET program called preBotHta.pdb, which the threat group has been using since 2019. There were two notable features for the 2021 variant of the preBotHta file: first, it ran entirely in memory and, second, it contained logic to alter the placement of ReverseRat if the host machine ran a certain anti-virus product.

The last action that preBotHta took was to start the execution of ReverseRat, which used Windows Management Instrumentation (WMI) to obtain information about the MAC address, physical memory on the device, processor (max clock speed, name, manufacturer), etc. The malware then RC4-encrypted the data with a key and sent it to the C&C server.

The second HTA file contained an encoded command to modify a registry key, the loader, and AllaKore (which gave access to the compromised network).

APT name	Regions attacked	Operation start
SharpPanda	South-East Asia	2018

Security specialists discovered an ongoing surveillance operation believed to be linked to China. The hackers are targeting organizations in South-East Asia with the aim of deploying spyware on Windows systems. The experts say the threat actors had stayed under the radar for more than three years.

The infection chain works by sending decoy documents impersonating government entities to multiple members of the Ministry of Foreign Affairs. When opened, a decoy document retrieves a next-stage payload from the C&C server that contains an encrypted downloader. The downloader, in turn, gathers and exfiltrates system information to a remote server that subsequently responds back with a shellcode loader.

The loader establishes connection with the remote server to download, decrypt, and execute an implant dubbed "VictoryDll_x86.dll," which is capable of performing file operations, capturing screenshots, creating and terminating processes, and even shutting down the infected machine.

The specialists said the adversary put significant effort into concealing its activity by changing the infrastructure multiple times since its development in 2017, with the backdoor receiving its own fair share of revisions to make it more resilient to analysis and decrease the detection rates at each stage.

The campaign has been linked to a Chinese threat group the specialists call SharpPanda based on test versions of the backdoor dating back to 2018 that were uploaded to VirusTotal from China and the threat actors' use of the Royal Road RTF weaponizer.

APT name	Regions attacked	Operation start

Mustang Panda	Myanmar	2021

Myanmar President's website suffered a watering hole attack. Hackers implanted a Cobalt Strike backdoor inside a localized downloadable font package. Security researchers suspect that the Mustang Panda APT (also known as Bronze President) could have been involved in the attack but cannot confirm the attribution.

Myanmar President's website was also hacked in 2015, when it was used to disseminate the Evilgrab malware.

In February this year, the Myanmar military overthrew the government. The country's current military leadership does not agree with China on a number of points, which explains Chinese hackers' interest in Myanmar.

Mustang Panda is a Chinese threat group active since at least 2014. Its main targets are governmental and non-governmental organizations and national minorities.

APT name	Regions attacked	Operation start
PuzzleMaker	Global	April 2021

Security researchers discovered a new threat group dubbed PuzzleMaker, which used a chain of Google Chrome and Windows 10 zero-day exploits in targeted attacks worldwide. The first attacks were detected mid-April 2021.

The zero-day exploit chain deployed in the campaign used a remote code execution vulnerability in the Google Chrome V8 JavaScript engine and two vulnerabilities in Windows: CVE-2021-31955 (an information disclosure vulnerability in the Windows kernel) and CVE-2021-31956 (a Windows NTFS privilege escalation bug).

The threat actors gain access to the target system through a vulnerability in Chrome and then exploit CVE-2021-31955 and CVE-2021-31956 to compromise Windows. The experts say PuzzleMaker abused the Windows Notification Facility (WNF) together with the CVE-2021-31956 vulnerability to execute malware modules on the target systems.

Besides the aforementioned exploits, the full attack chain involves other malicious modules. One of them is a stager module, which is used to notify that the exploitation has been successful. It also downloads and executes a more complex malware dropper module from a remote server. The dropper module is used to install two executables that pretend to be legitimate files belonging to Microsoft Windows OS. One of them is a remote shell, which is able to download and upload files, create processes, sleep for specified amounts of time, and delete itself from the compromised machine.

APT name	Regions attacked	Operation start
Gelsemium	Taiwan, Hong Kong, Sri Lanka, East Asia, Middle East	2014

Security specialists published details about an APT group called Gelsemium, which they believe is behind a supply-chain attack.

A February campaign, known as NightScout, targeted the update mechanism of NoxPlayer, an Android emulator for PCs and Macs popular among gamers and part of the Hong Kong firm BigNox's product range

with over 150 million users worldwide. Operation NightScout affected a small number of targets in Taiwan, Hong Kong, and Sri Lanka, which indicates that the attacks were highly targeted.

The threat group specializes in cyber espionage and has been active since at least 2014. The group's main targets have lately been governmental institutions, electronics manufacturers, universities and religious organizations in East Asia and the Middle East.

During their analysis of Gelsemium's campaigns, the experts found early versions of the "complex and modular" Gelsevirine backdoor. To collect information, the group uses several components, in particular, the Gelsemine dropper, the Gelsenicine loader, and Gelsevirine.

The experts observed that the group's attack vectors include phishing emails with attachments exploiting a vulnerability in Microsoft Office (CVE-2012-0158), which allows for remote code execution.

In addition, Gelsemium carries out watering hole attacks, uses exploits that make it possible to deploy web shells in vulnerable Microsoft Exchange servers, and uses Dynamic DNS (DDNS) domain names for C&C servers to hinder infrastructure tracking.

APT name	Regions attacked	Operation start
BackdoorDiplomacy	Africa, Asia, Europe, Middle East	2017

A new APT group called BackdoorDiplomacy due to the main vertical of its victims has been targeting ministries of foreign affairs and telecommunication companies in Africa and the Middle East since at least 2017. For initial infection vectors, the group favors exploiting vulnerable Internet-exposed devices such as web servers and management interfaces for networking equipment.

Once on a system, the operators make use of open-source tools for scanning the environment and lateral movement. Interactive access is achieved in two ways: (1) via a custom backdoor called Turian, which is derived from the Quarian backdoor; and (2) in fewer instances, when more direct and interactive access is required, certain open-source remote access tools are deployed. In several instances, the group has been observed targeting removable media for data collection and exfiltration. Finally, both Windows and Linux operating systems have been targeted.

Security specialists did not attribute BackdoorDiplomacy to any country, but a number of factors suggests that the group may be linked to China. In particular, this is indicated by the use of compromise mechanisms that have earlier been seen in attacks linked to Chinese threat groups as well as the fact that the Turian backdoor is based on Quarian, a malware strain that has been used in attacks by Chinese hackers.

APT name	Regions attacked	Operation start
Ferocious Kitten	Iran	2015

Security researchers reported that Iran-linked threat actors, tracked as Ferocious Kitten, used instant messaging apps and VPN software like Telegram and Psiphon to deliver a Windows RAT and spy on targets.

The cyber spies have been stealing sensitive information from their victims since at least 2015; they targeted the two platforms because of their popularity in Iran. Experts pointed out that some of the TTPs used by this APT group overlapped with those associated with other groups that are active against a similar set of targets, such as Domestic Kitten and Rampant Kitten.

The decoy content displayed by malicious files employed in the attacks often made use of political themes and involved images or videos of resistance bases or strikes against the Iranian regime, a circumstance that suggests that the attack is aimed at potential supporters of such movements within the country.

The experts spotted the activity of the group by investigating two weaponized documents that were uploaded to VirusTotal in July 2020 and March 2021. The two documents include macros used to launch a multi-stage infection aimed at deploying a previously undocumented implant called MarkiRat.

The malware allows attackers to steal victims' data, record keystrokes, provide file download and upload capabilities, capture clipboard content, and execute arbitrary commands on the infected system.

The researchers also discovered that the C&C infrastructure hosted Android applications in the form of DEX and APK files, likely to target mobile users.

APT name	Regions attacked	Operation start
APT31	Norway	2018

Norway's Police Security Service (PST) said that the China-linked APT31 cyberespionage group was behind the attack that breached the government's IT network in 2018.

"The investigation has revealed that the actor succeeded in acquiring administrator rights that gave access to centralized computer systems used by all state administration offices in the country," reads the statement published by the Norwegian intelligence agency.

The threat actors also succeeded in transferring some data from the offices' systems. No reliable technical findings have been made of what information was transferred, but the investigation shows that there were probably usernames and passwords associated with employees in various state administration offices."

The PST has found no evidence that the threat actors exfiltrated government secrets or personal sensitive information related to Norwegian citizens.

Interestingly, the official press release does not mention a direct link between the attack and APT31. However, Hanne Blomberg, the head of counterintelligence at the PST, shared that information in an interview for NRK, a government-owned broadcasting company.

APT31 is characterized as an actor specialized in intellectual property theft, focusing on data and projects that make a particular organization competitive in its field. Based on available data, security specialists believe that APT31 conducts network operations at the behest of the Chinese government.

APT name	Regions attacked	Operation start
Unknown hackers attack Zyxel devices	Global	2021

In late June, the networking equipment vendor Zyxel emailed its customers to alert them about a series of attacks that targeted some of the company's high-end enterprise-focused firewall and VPN server products.

"We recently became aware of a sophisticated threat actor targeting a small subset of Zyxel security appliances that have remote management or SSL VPN enabled," the company said.

The attacks have targeted the USG, ZyWALL, USG FLEX, ATP, and VPN series running on-premise ZLD firmware. All are multi-purpose networking devices.

The vendor says the threat actor attempts to access a device through WAN; if successful, they then bypass authentication and establish SSL VPN tunnels with unknown user accounts, such as zyxel_sllvpn, zyxel_ts, or zyxel_vpn_test, to manipulate the device's configuration.

It is unclear if the attacker exploits an old vulnerability or if they use a never-before-seen bug. It is also unclear if the attacks have already resulted in security breaches at some of Zyxel's customers or if the vendor caught the attack in early stages and is now warning clients as a preventive measure.

APT name	Regions attacked	Operation start
RedFoxtrot	Central Asia, India, Pakistan, Afghanistan, Kazakhstan	2014

Security researchers identified ties between the RedFoxtrot threat group and China's People's Liberation Army (PLA) Unit 69010 located in Ürümqi, Xinjiang.

Unit 69010 is part of Technical Reconnaissance Bureau (TRB) within the PLA Strategic Support Force (SSF) Network Systems Department (NSD). SSF is a space-, cyber- and electronic-warfare force.

The researchers were able to make connections between PLA Unit 69010 and RedFoxtrot's cyber-espionage campaigns focused on gathering military intelligence from neighboring countries due to lax operational security (OpSec) measures of a RedFoxtrot operator, which revealed the physical address of Unit 69010's headquarters.

RedFoxtrot attacks predominantly target the government, telecommunications and defense sectors across Central Asia, India, and Pakistan. Within the past six months, the group targeted three Indian aerospace and defense contractors; major telecommunications providers in Afghanistan, India, Kazakhstan, and Pakistan; and multiple government agencies across the region.

The group's attacks involve open-source and custom hacking tools, including PlugX family backdoors, Royal Road RTF weaponizer, QUICKHEAL, PCShare, IceFog, and the Poison Ivy RAT.

RedFoxtrot also uses AXIOMATICASYMPTOTE infrastructure, which encompasses a modular Windows backdoor called ShadowPad.

Group-IB specialists believe the activity of this group is similar to that of APT41, another Chinese threat actor. In addition, part of the infrastructure overlaps between the groups.

APT name	Regions attacked	Operation start
SideWinder	Pakistan, China, Nepal	November 2020

Between April and June, Sidewinder attacks against Pakistan, China, and Nepal were detected.

The threat actors send phishing emails to their victims with a malicious attachment in the .doc, .rtf, or .xls format. The files are disguised as legitimate official documents of the entities the threat actors are attacking. To establish persistence in the target system Sidewinder uses vulnerability CVE-2017-11882.

In Sidewinder's malware samples, security researchers found data of a Telegram bot, to which a stealer sends information collected from infected hosts. This data includes cookies from browsers and information about the victim computer such as directory listings, volume serial number, and machine name.

Phishing domains (sometimes C&C too) used by the group usually mimic legitimate domains of government organizations in attacked countries.

The C&C domains are often disguised as legitimate domains of Microsoft services.

The SideWinder group (also known as Rattlesnake, Hardcore Nationalist (HN2), T-APT-04, and APT-C-17) has been active since at least 2012. The group engages in cyber espionage against targets in South Asian government entities (governments, the military). The group's attacks target both Windows and Android users.

APT	Regions attacked	Operation start
Lazarus	South Africa, Oman, South Korea, Russia	2020

Security researchers discovered a previously undocumented Lazarus backdoor, which they dubbed Vyveva, being used to attack a freight logistics company in South Africa. The backdoor consists of multiple components and communicates with its C&C server via the Tor network. So far, the researchers have been able to find its installer, loader and main payload – a backdoor with a TorSocket DLL. The previously unknown attack was discovered in June 2020. Although Vyveva has been used since at least December 2018, its initial compromise vector is still unknown.

In addition, security specialists continued analyzing a campaign called Operation Dream Job. The attack against job seekers in the aerospace and defense industries was discovered in 2019. The threat actors disguised as recruiters from well-known aerospace and defense companies and used business-related social media accounts to carry out the attacks. By using these accounts, the attackers lured job seekers with job-related posts.

In January 2021, JPCERT revealed two major malware strains utilized in attacks related to Operation Dream Job: Torisma, a piece of malware that was revealed in November 2020, and Lcpdot, a piece of malware that was introduced recently. AhnLab found out that three variants of Lcpdot were signed with the "2 TOY GUYS LLC" certificate and decided to analyze the files signed with the certificate. The analysis revealed that since spring 2020 the attacker had been using Lcpdot type malware to attack various countries, including Korea. It is assumed that the malware normally connects to three or four websites and uses a different C&C server address for each attack target based on the region and language.

On April 13, researchers identified a document used by Lazarus to target South Korea. In this campaign, Lazarus resorted to an interesting technique of BMP files embedded with malicious HTA objects to drop its Loader. This attack likely started by distributing phishing emails that were weaponized with a malicious document.

Further, it came to light that in late September 2020 Lazarus attacked a pharmaceutical company. At the end of September 2020, an employee of the pharmaceutical company received a document named "GD2020090939393903.doc" with a job offer (creation date: 2020:09:22 03:08:00). After a short period of time, another employee received a document named "GD20200909GAB31.doc" with a job offer from the same company (creation date: 2020:09:14 07:50:00). By opening the documents from a potential employer, both victims activated malicious macros on their home computers.

One of the compromised computers used the CommsCacher backdoor. At the beginning of the working week, both victims connected to the RDG server of one of the organization's branches from the compromised personal computers. This allowed the attackers to gain access to the company's corporate network.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.